BÁO CÁO THỰC HÀNH

Thực hành An toàn mạng máy tính

Lab 03: Quét lỗ hổng bảo mật với Nessus

GVTH: Nguyễn Ngọc Trưởng

Ngày báo cáo: 02/05/2026

Nhóm 05 – NT101.Q22.1

THÔNG TIN CHUNG

MSSV	Họ và tên	Nội dung báo cáo	% công việc
24522019	Nguyễn Phú Vinh	Nhiệm vụ 2.3 2.4	50%
24522028	Võ Lê Thành Vinh	Nhiệm vụ 2.1 2.2	50%

A. Thiết lập môi trường trước khi làm thực hành

Cấu hình mô hình mạng:

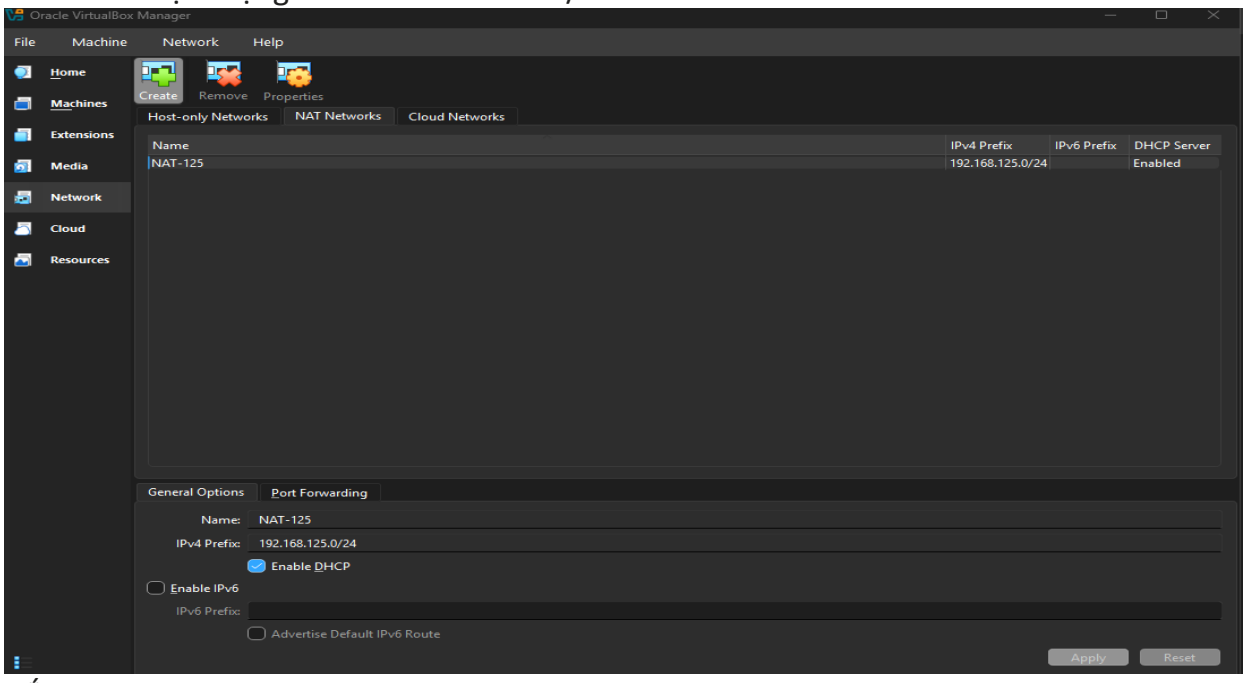
Yêu cầu mô hình mạng:

– Network address: 192.168.125.0/24

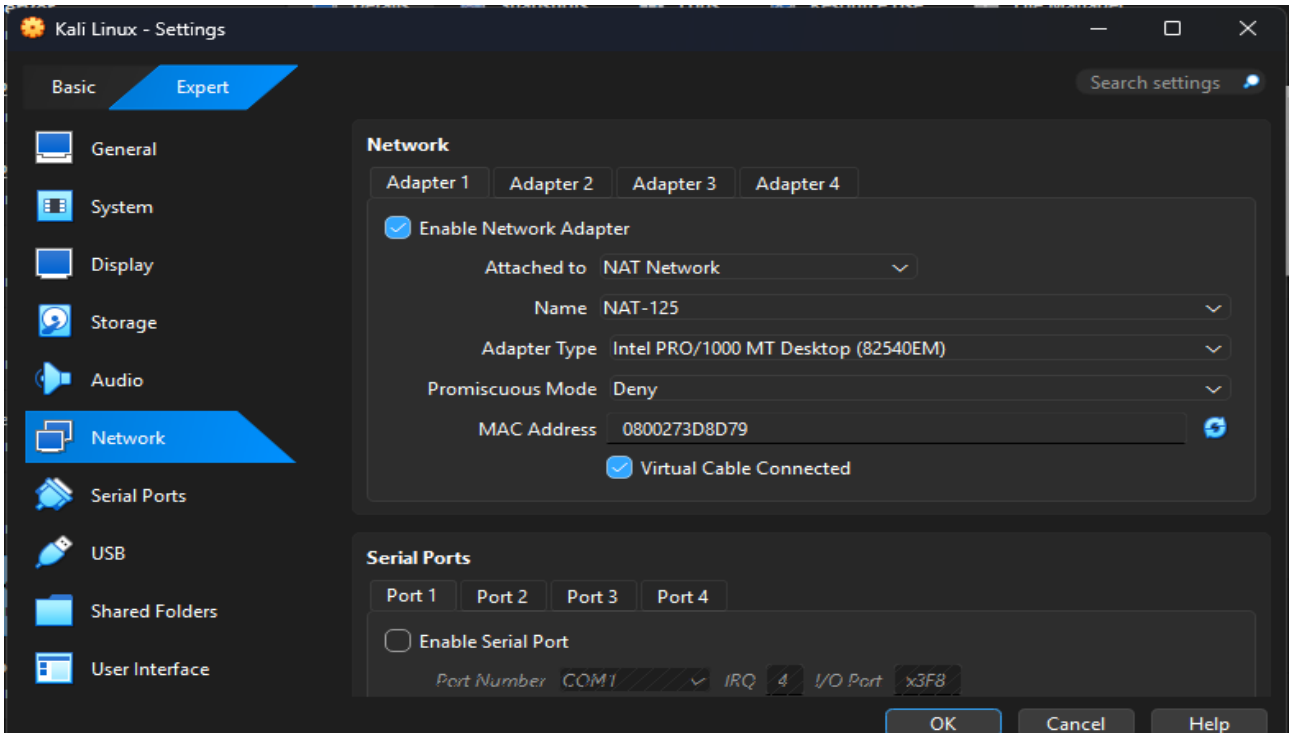
– Máy ảo Linux: (192.168.125.105)

– Metasploitable 2: (192.168.125.221)

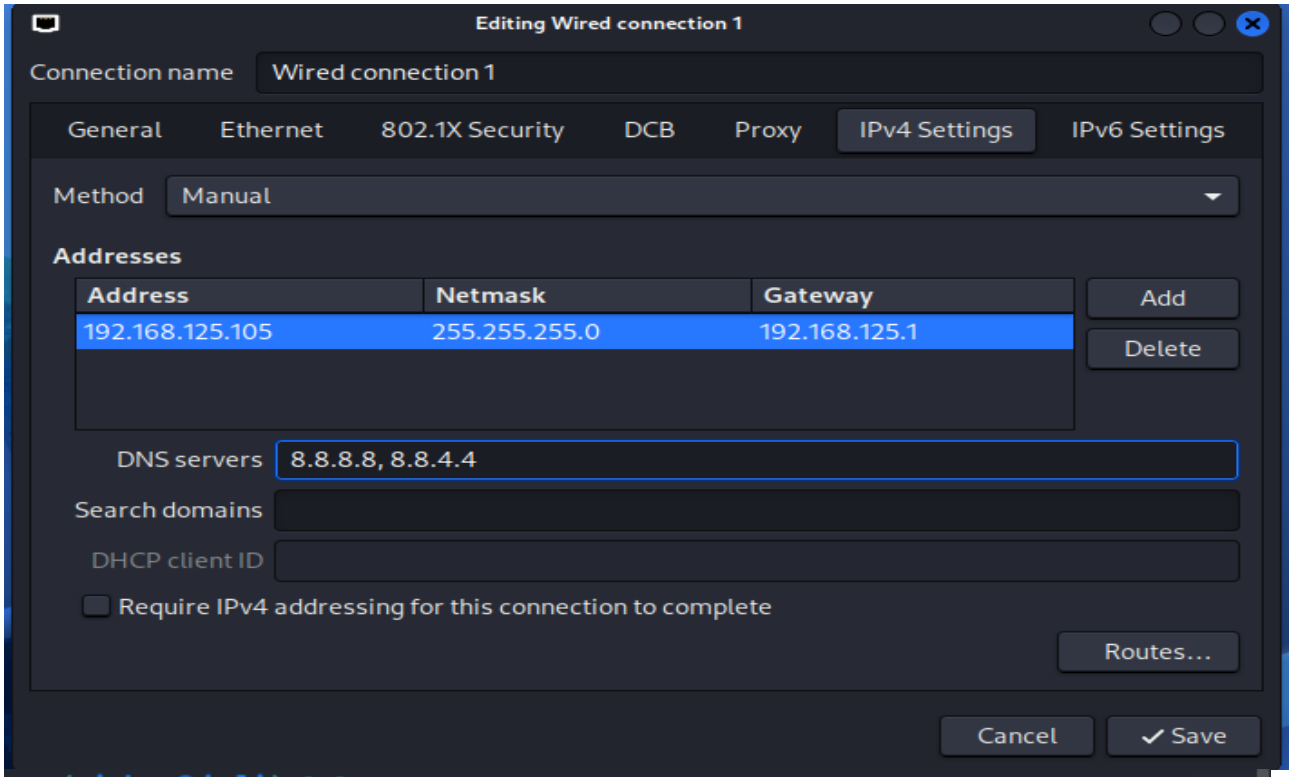
Tiến hành Tạo mạng NAT 192.168.125.0/24 trên Oracle VirtualBox

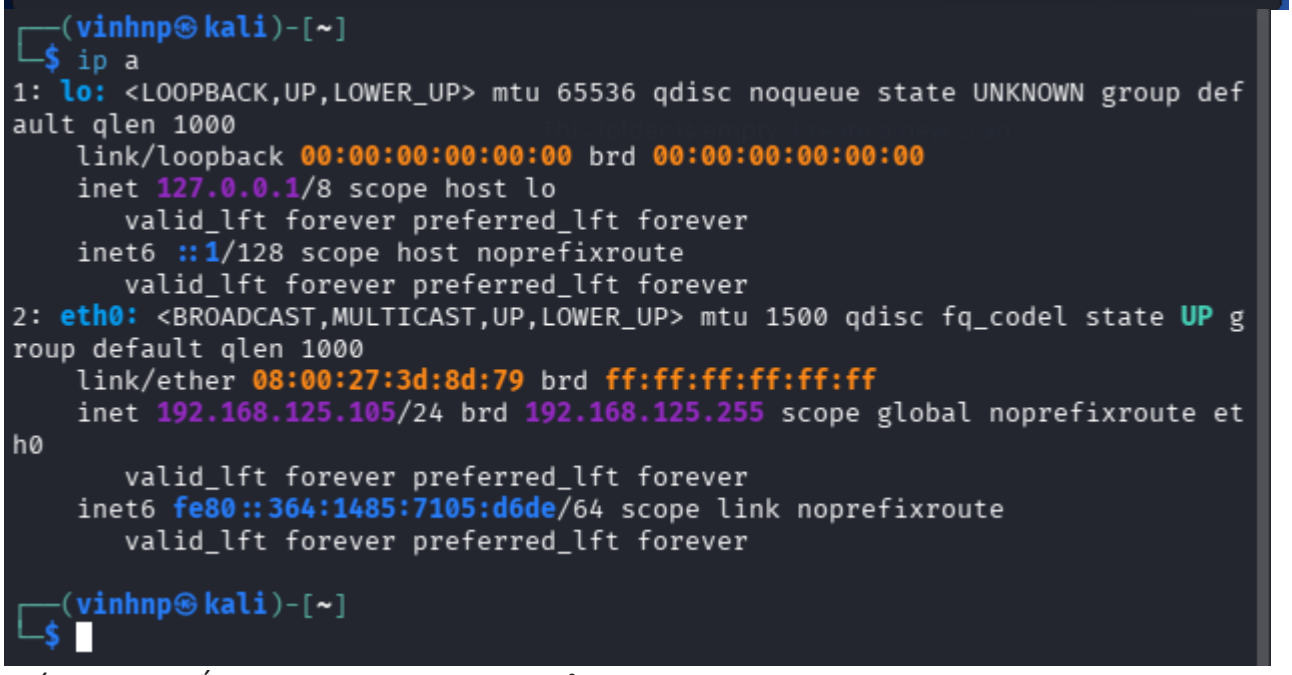


Gắn NAT Network vào cho Kali Linux:

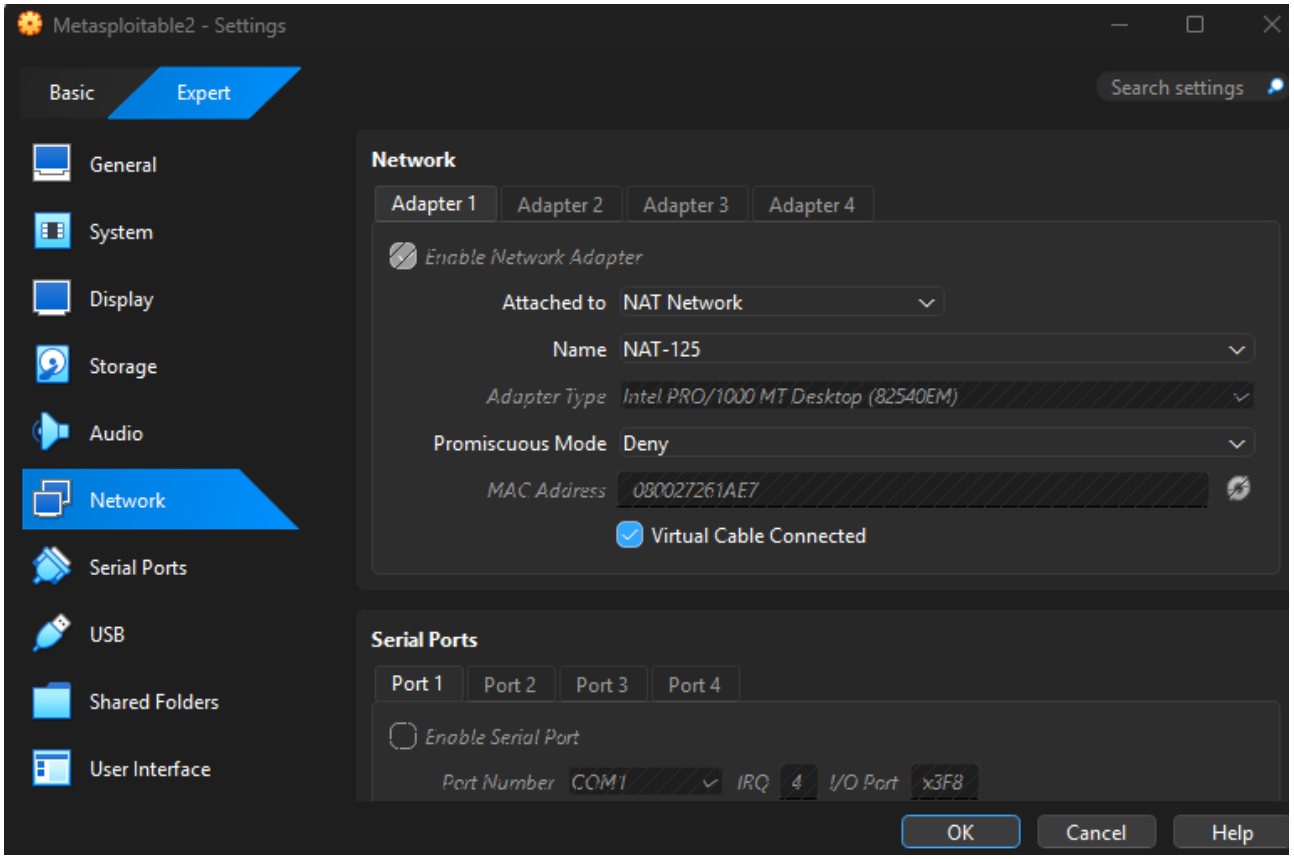


Tiếp theo ta tiến hành cấp IP tĩnh 192.168.125.105 cho Kali Linux:





Tiếp theo ta gắn NAT Network cho máy ảo Metasploitable 2:



Ta tiến hành cấp IP Tĩnh (192.168.125.221) cho Metasploitable 2:

Ta mở file cấu hình mạng bằng lệnh sau:

```
sudo nano /etc/network/interfaces
```

Ta chỉnh lại config cấu hình mạng như sau:

```
Metasploitable2 [Running] - Oracle VirtualBox
File   Machine   View   Input   Devices   Help

  GNU nano 2.0.7          File: /etc/network/interfaces                Modified

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
iface eth0 inet static
address 192.168.125.221
gateway 192.168.125.1
dns-nameservers 8.8.8.8 8.8.4.4

^G Get Help  ^O WriteOut  ^R Read File ^Y Prev Page ^K Cut Text  ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is  ^V Next Page ^U UnCut Text^T To Spell
Right Ctrl
```

Thành công cấp IP Tĩnh cho metasploitable 2 (192.168.125.221):

```
msfadmin@metasploitable:~$ sudo /etc/init.d/networking restart
 * Reconfiguring network interfaces...                                [ OK ]
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:26:1a:e7 brd ff:ff:ff:ff:ff:ff
    inet 192.168.125.221/24 brd 192.168.125.255 scope global eth0
    inet6 fe80::a00:27ff:fe26:1ae7/64 scope link tentative
       valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

Từ IP của Kali Linux (192.168.125.105) ta ping được qua Metasploitable 2 (192.168.125.221)

```
vinhnp@kali: ~
Session  Actions  Edit  View  Help
64 bytes from 192.168.125.221: icmp_seq=17 ttl=64 time=11.2 ms
64 bytes from 192.168.125.221: icmp_seq=18 ttl=64 time=7.16 ms
dasdsa
64 bytes from 192.168.125.221: icmp_seq=19 ttl=64 time=2.12 ms
64 bytes from 192.168.125.221: icmp_seq=20 ttl=64 time=13.7 ms
64 bytes from 192.168.125.221: icmp_seq=21 ttl=64 time=0.853 ms
^X@s 64 bytes from 192.168.125.221: icmp_seq=22 ttl=64 time=1.59 ms
64 bytes from 192.168.125.221: icmp_seq=23 ttl=64 time=1.65 ms
64 bytes from 192.168.125.221: icmp_seq=24 ttl=64 time=13.2 ms
64 bytes from 192.168.125.221: icmp_seq=25 ttl=64 time=14.0 ms
64 bytes from 192.168.125.221: icmp_seq=26 ttl=64 time=0.971 ms
64 bytes from 192.168.125.221: icmp_seq=27 ttl=64 time=14.4 ms
64 bytes from 192.168.125.221: icmp_seq=28 ttl=64 time=8.01 ms
64 bytes from 192.168.125.221: icmp_seq=29 ttl=64 time=14.5 ms
64 bytes from 192.168.125.221: icmp_seq=30 ttl=64 time=13.1 ms
64 bytes from 192.168.125.221: icmp_seq=31 ttl=64 time=0.710 ms
64 bytes from 192.168.125.221: icmp_seq=32 ttl=64 time=16.5 ms
64 bytes from 192.168.125.221: icmp_seq=33 ttl=64 time=6.73 ms
64 bytes from 192.168.125.221: icmp_seq=34 ttl=64 time=6.46 ms
64 bytes from 192.168.125.221: icmp_seq=35 ttl=64 time=1.29 ms
64 bytes from 192.168.125.221: icmp_seq=36 ttl=64 time=0.704 ms
^C
--- 192.168.125.221 ping statistics ---
36 packets transmitted, 36 received, 0% packet loss, time 36280ms
rtt min/avg/max/mdev = 0.704/5.517/16.540/5.266 ms

┌──(vinhnp㉿kali)-[~]
└─$
```

Tiếp theo ta tiến hành cài Nessus trên Kali Linux:

Đầu tiên ta tiến hành tài Nessus về từ website chính, sau đó tiến hành cài đặt Nessus:

```
vinhnp@kali: ~/Downloads
Session  Actions  Edit  View  Help
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass
HASH : (DRBG) : Pass
CTR : (DRBG) : Pass
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
        name:           OpenSSL FIPS Provider
        version:        3.1.2
        build:          3.1.2
INSTALL PASSED
Unpacking Nessus Scanner Core Components...

 - You can start Nessus Scanner by typing /bin/systemctl start nessusd.servic
e
 - Then go to https://NESSUS_HOSTNAME_OR_IP:8834/ to configure your scanner

Notice: Download is performed unsandboxed as root as file '/home/vinhnp/Downl
oads/Nessus-10.12.0-debian10_amd64.deb' couldn't be accessed by user '_apt'.
- pkgAcquire::Run (13: Permission denied)

┌──(vinhnp㉿kali)-[~/Downloads]
└─$
```

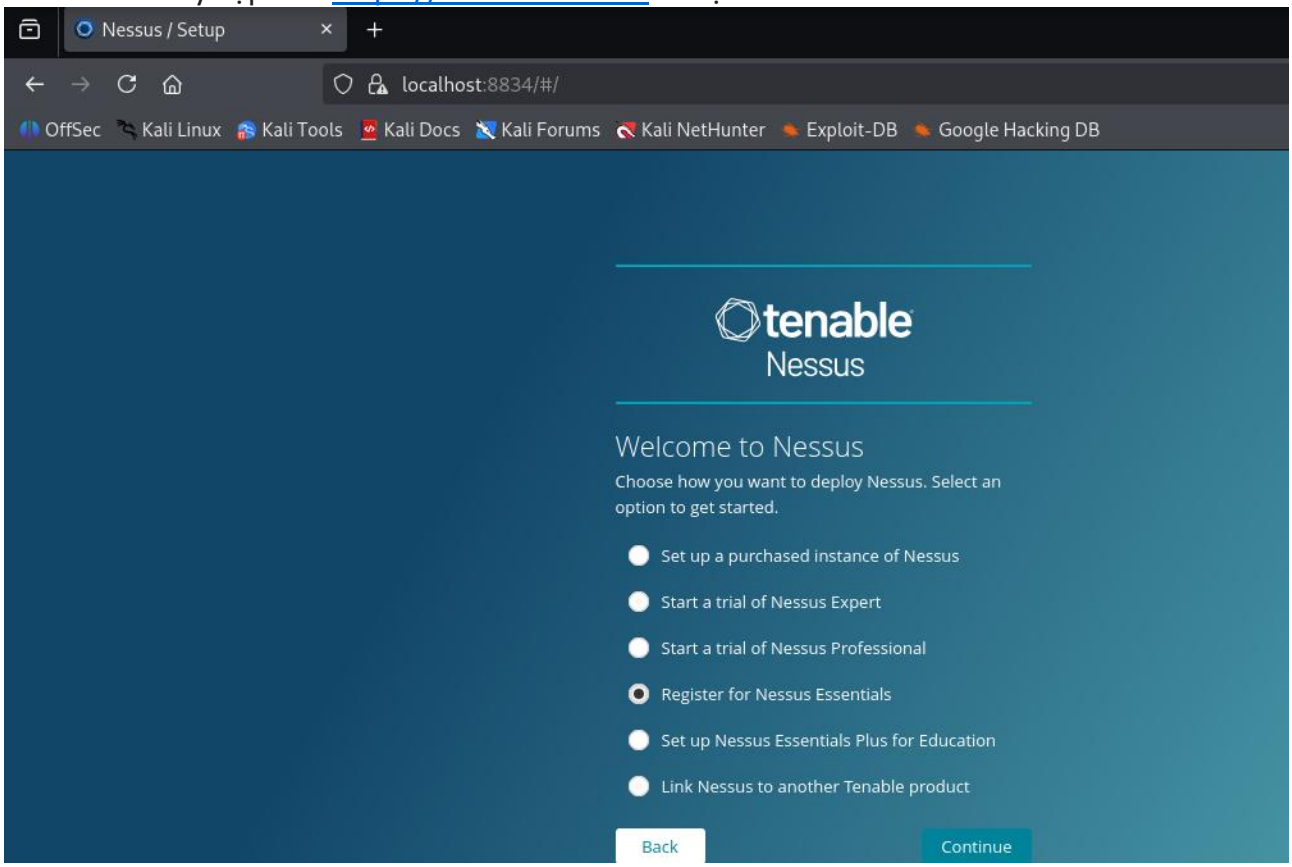
Khởi động Nessus bằng lệnh:

/bin/systemctl start nessusd.service

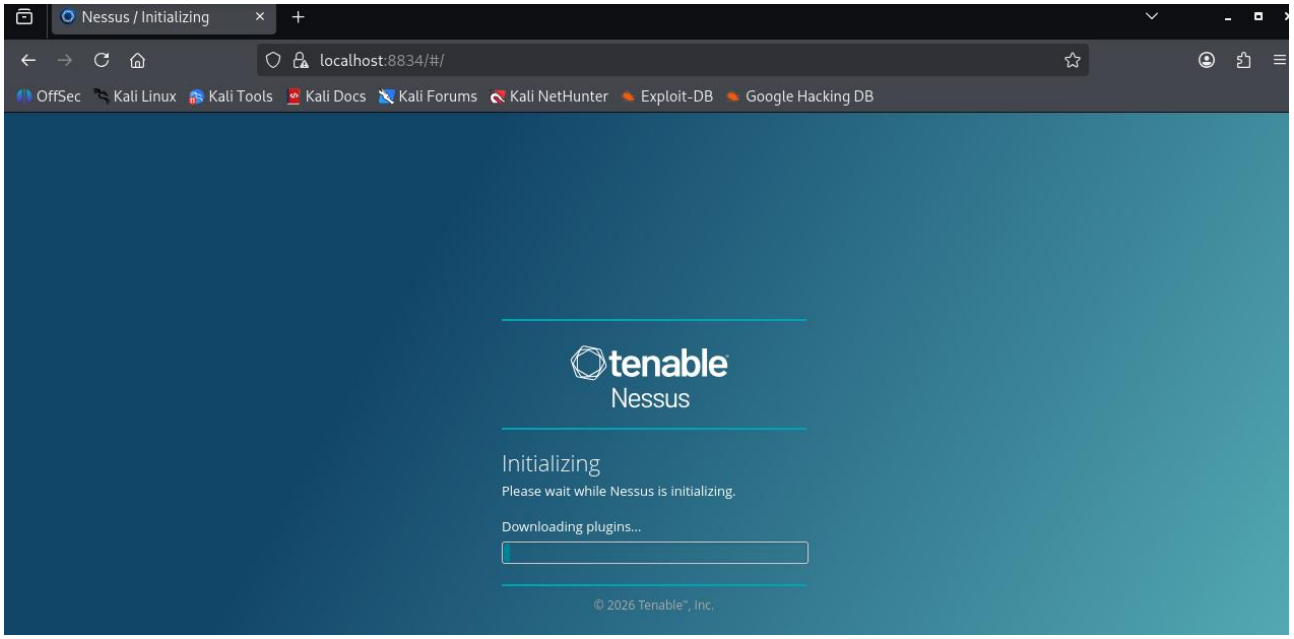
```
┌──(vinhnp㉿kali)-[~/Downloads]
└─$ systemctl status nessusd
● nessusd.service - The Nessus Vulnerability Scanner
     Loaded: loaded (/usr/lib/systemd/system/nessusd.service; disabled; pres>
     Active: active (running) since Fri 2026-05-01 23:22:26 +08; 40s ago
 Invocation: f82daae14acb49fd9b8db7d90d9125d6
   Main PID: 16200 (nessus-service)
      Tasks: 16 (limit: 4450)
     Memory: 150.5M (peak: 150.5M)
        CPU: 38.714s
     CGroup: /system.slice/nessusd.service
             ├─16200 /opt/nessus/sbin/nessus-service -q
             └─16214 nessusd -q

May 01 23:22:26 kali systemd[1]: Started nessusd.service - The Nessus Vulner>
May 01 23:22:26 kali nessus-service[16200]: nessus-service [16200][INFO] : N>
lines 1-14/14 (END)
```

Tiến hành truy cập vào https://localhost:8834 và tạo tài khoản:



Hoàn tất việc đăng ký:

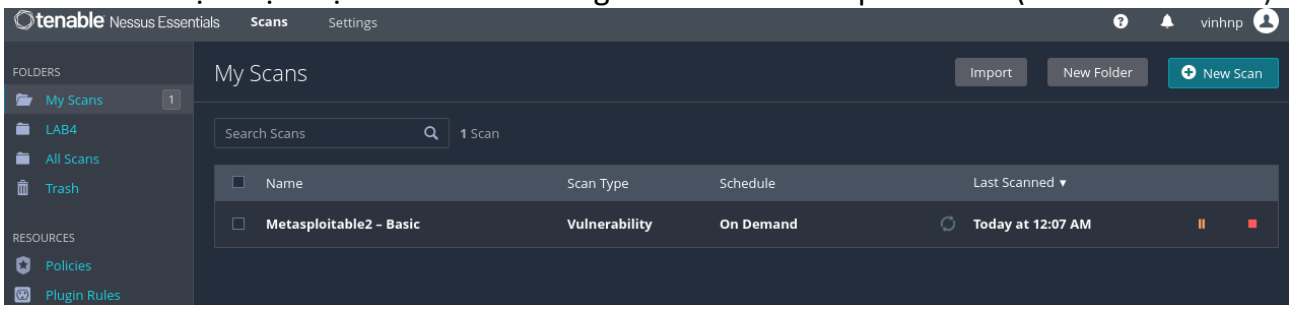


B. Nội dung thực hành

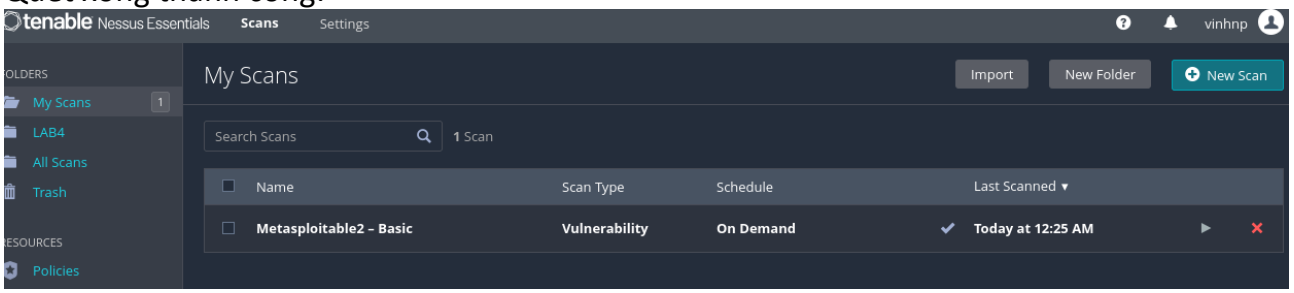
Nhiệm vụ 2.1

1. Thực hiện lại các bước trên để quét máy Metasploitable 2 không sử dụng tài khoản chứng thực.

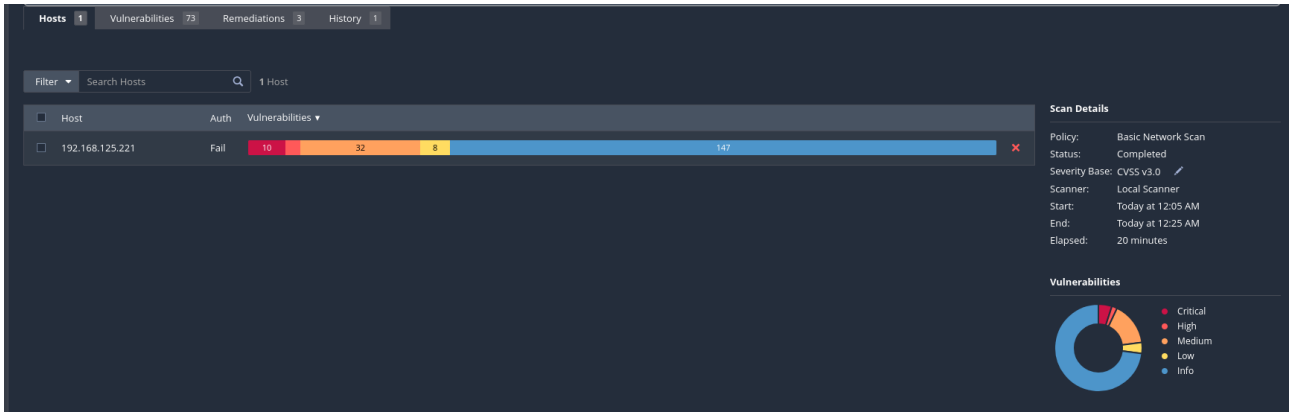
Ta bắt đầu thực hiện việc scan mới với target là IP của metasploitable 2 (192.168.125.221).



Quét xong thành công:



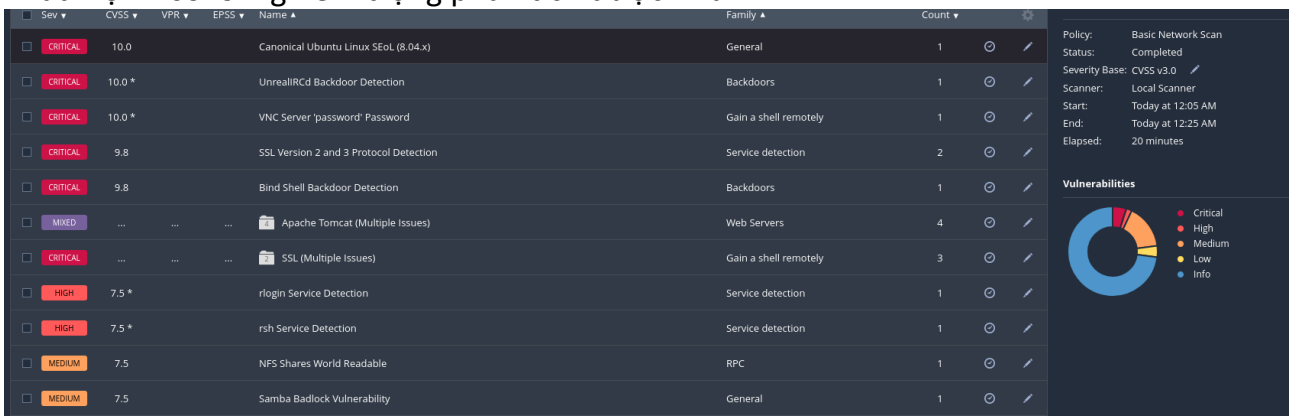
Tổng quan sau khi quét:



Có tổng 73 Lỗ hổng được tìm thấy sau khi quét.

- Critical (Đỏ): Nghiêm trọng
- High (Cam đậm): Cao
- Medium (Cam): Trung bình
- Low (Vàng): Thấp
- Info (Xanh dương): Thông tin

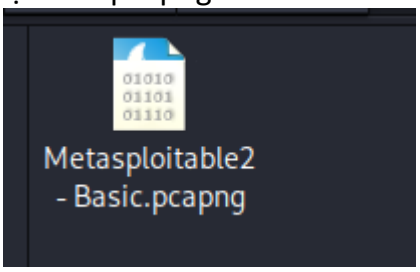
Phát hiện 1 số lỗi nghiêm trọng phân tích được như:



- Hệ điều hành hết hạn, không còn được cập nhật bảo mật.
- Mật khẩu mặc định dễ bị khai thác từ xa.
- Giao thức SSL lỗi thời, không an toàn.
- Có thể bị tấn công Bind Shell.
- Phát hiện có backdoor.

2. Bật Wireshark sau đó tiến hành quét và xác định các bước mà Nessus đã thực hiện để hoàn tất quá trình quét.

Sau khi hoàn tất quét ta thu được file .pcapng như sau:



Ở các gói tin đầu tiên, các gói tin qua giao thức ARP để xác định địa chỉ MAC của máy mục tiêu:

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.125.105	8.8.8.8	DNS	77	Standard query 0x79b0 A chk.l2.nessus.org
2	0.161753958	8.8.8.8	192.168.125.105	DNS	93	Standard query response 0x79b0 A chk.l2.nessus.org A 255.255.255.255
3	0.171883806	192.168.125.105	8.8.8.8	DNS	112	Standard query 0x554f A tm3bbbiaalwtqelemvrgsylogeyc26bygywtmna.h.nessus.org
4	0.410986148	8.8.8.8	192.168.125.105	DNS	128	Standard query response 0x554f A tm3bbbiaalwtqelemvrgsylogeyc26bygywtmna.h.nessus.org A 1.1.1.1
5	0.492780823	PCSSystemtec_3d:8d:…	Broadcast	ARP	60	Who has 192.168.125.221? Tell 192.168.125.105
6	0.498839561	PCSSystemtec_26:1a:…	PCSSystemtec_3d:8d:…	ARP	60	192.168.125.221 is at 08:00:27:26:1a:e7
7	0.524755371	PCSSystemtec_3d:8d:…	Broadcast	ARP	60	Who has 169.254.91.76? Tell 192.168.125.105
8	1.552666995	PCSSystemtec_3d:8d:…	Broadcast	ARP	60	Who has 169.254.91.76? Tell 192.168.125.105
9	2.580971032	PCSSystemtec_3d:8d:…	Broadcast	ARP	60	Who has 169.254.91.76? Tell 192.168.125.105
10	3.620790750	PCSSystemtec_3d:8d:…	Broadcast	ARP	60	Who has 169.254.91.76? Tell 192.168.125.105
11	4.668868467	PCSSystemtec_3d:8d:…	Broadcast	ARP	42	Who has 192.168.125.221? Tell 192.168.125.105
12	4.669547182	PCSSystemtec_26:1a:…	PCSSystemtec_3d:8d:…	ARP	60	192.168.125.221 is at 08:00:27:26:1a:e7
13	4.669563862	192.168.125.105	192.168.125.221	TCP	74	53608 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=279299261 TSecr=0 WS=512
14	4.669640722	192.168.125.105	192.168.125.221	TCP	74	41400 → 81 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=2390005422 TSecr=0 WS=512
15	4.669699869	192.168.125.105	192.168.125.221	TCP	74	54148 → 8009 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3417398894 TSecr=0 WS=512
16	4.670525812	192.168.125.221	192.168.125.105	TCP	74	80 → 53608 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=122000 TSecr=279299261 WS=32
17	4.670526133	192.168.125.221	192.168.125.105	TCP	60	81 → 41400 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
18	4.670526183	192.168.125.221	192.168.125.105	TCP	74	8009 → 54148 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=122000 TSecr=3417398894 WS=32
19	4.670555637	192.168.125.105	192.168.125.221	TCP	66	53608 → 80 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=279299262 TSecr=122000
20	4.670634710	192.168.125.105	192.168.125.221	TCP	66	54148 → 8009 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=3417398895 TSecr=122000
21	4.721497411	192.168.125.105	192.168.125.221	HTTP	84	GET / HTTP/1.0

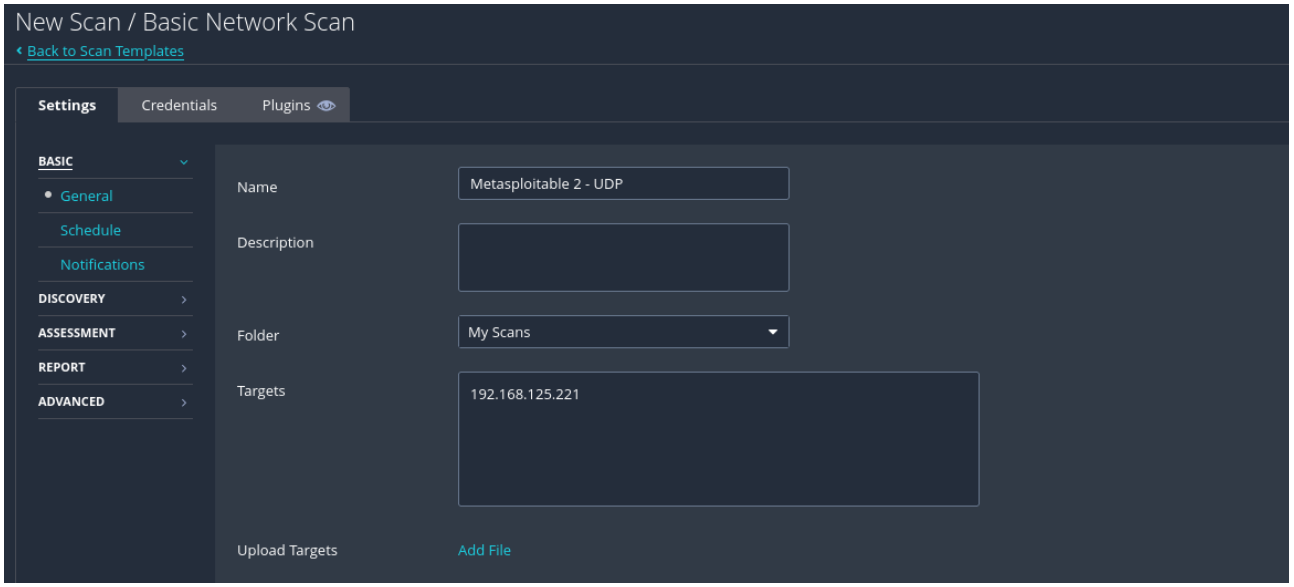
Sau khi xác định mục tiêu cần quét (192.168.125.221), Nessus tiến hành quét cổng, có thể thấy chi tiết thông qua việc nó gửi đi các gói TCP SYN từ máy nguồn đến máy đích thông qua các cổng khác nhau.

No.	Time	Source	Destination	Protocol	Length	Info
19	4.670555637	192.168.125.105	192.168.125.221	TCP	66	53608 → 80 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=279299262 TSecr=122000
20	4.670634710	192.168.125.105	192.168.125.221	TCP	66	54148 → 8009 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=3417398895 TSecr=122000
21	4.721497411	192.168.125.105	192.168.125.221	HTTP	84	GET / HTTP/1.0
22	4.722422714	192.168.125.221	192.168.125.105	TCP	66	80 → 53608 [ACK] Seq=1 Ack=19 Win=5792 Len=0 TSval=122002 TSecr=279299313
23	5.148221002	192.168.125.221	192.168.125.105	TCP	647	80 → 53608 [PSH, ACK] Seq=1 Ack=19 Win=5792 Len=581 TSval=122015 TSecr=279299313 [TCP PDU reassembled in 29]
24	5.148221392	192.168.125.221	192.168.125.105	TCP	483	80 → 53608 [PSH, ACK] Seq=582 Ack=19 Win=5792 Len=417 TSval=122015 TSecr=279299313 [TCP PDU reassembled in 29]
25	5.148256707	192.168.125.105	192.168.125.221	TCP	66	53608 → 80 [ACK] Seq=19 Ack=582 Win=64000 Len=0 TSval=279299740 TSecr=122015
26	5.148326984	192.168.125.105	192.168.125.221	TCP	66	53608 → 80 [ACK] Seq=19 Ack=999 Win=64000 Len=0 TSval=279299740 TSecr=122015
27	5.148712225	192.168.125.221	192.168.125.105	TCP	133	80 → 53608 [PSH, ACK] Seq=999 Ack=19 Win=5792 Len=67 TSval=122015 TSecr=279299740 [TCP PDU reassembled in 29]
28	5.148719709	192.168.125.105	192.168.125.221	TCP	66	53608 → 80 [ACK] Seq=19 Ack=1066 Win=64000 Len=0 TSval=279299741 TSecr=122015
29	5.152227571	192.168.125.221	192.168.125.105	HTTP	66	HTTP/1.1 200 OK (text/html)
30	5.152947400	192.168.125.105	192.168.125.221	TCP	66	53608 → 80 [RST, ACK] Seq=19 Ack=1067 Win=64000 Len=0 TSval=279299745 TSecr=122015
31	5.153763134	192.168.125.105	192.168.125.221	HTTP	84	GET / HTTP/1.0
32	5.166735113	192.168.125.221	192.168.125.105	TCP	66	8009 → 54148 [ACK] Seq=1 Ack=19 Win=5792 Len=0 TSval=122015 TSecr=3417399379
33	5.182508670	192.168.125.221	192.168.125.105	TCP	66	8009 → 54148 [FIN, ACK] Seq=1 Ack=19 Win=5792 Len=0 TSval=122016 TSecr=3417399379
34	5.182695159	192.168.125.105	192.168.125.221	TCP	66	54148 → 8009 [RST, ACK] Seq=19 Ack=2 Win=64512 Len=0 TSval=3417399407 TSecr=122016
35	5.265269432	192.168.125.105	192.168.125.221	TCP	74	43320 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=995277444 TSecr=0 WS=512
36	5.268033290	192.168.125.221	192.168.125.105	TCP	74	22 → 43320 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=122019 TSecr=995277444 WS=32
37	5.268067713	192.168.125.105	192.168.125.221	TCP	66	43320 → 22 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=995277447 TSecr=122019
38	5.268378538	192.168.125.105	192.168.125.221	TCP	66	43320 → 22 [RST, ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=995277447 TSecr=122019
39	5.278406331	192.168.125.105	192.168.125.221	SNMP	85	get-next-request 1.3.6.1.2.1.1.1.0

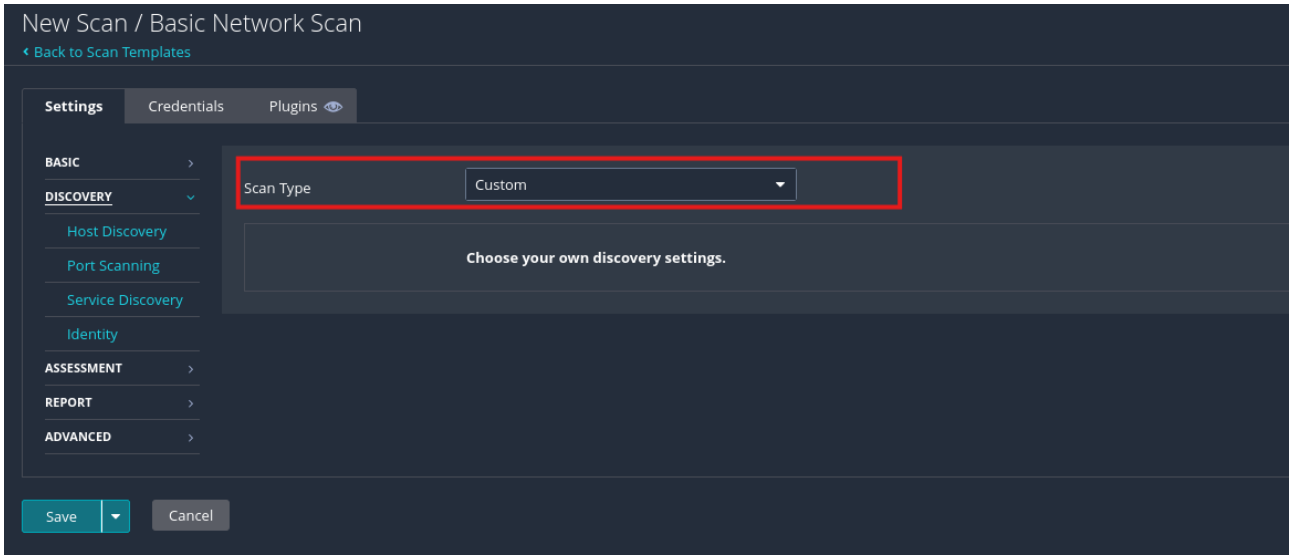
Dựa vào các thông tin đã thu thập được, Nessus sẽ chạy các plugin đã được cấu hình để kiểm tra các lỗ hổng đã biết như: lỗ hổng phần mềm, lỗ hổng cấu hình sai, lỗ hổng bảo mật web, lỗ hỏng bảo mật liên quan chứng chỉ SSL/TLS, và sau khi kiểm tra tất cả lỗ hổng, Nessus sẽ tiến hành tạo cáo cáo và tổng hợp thông tin về các lỗ hổng hiện có trên máy mục tiêu như hiển thị trên web

3. Quét lại nhưng quét thêm port UDP

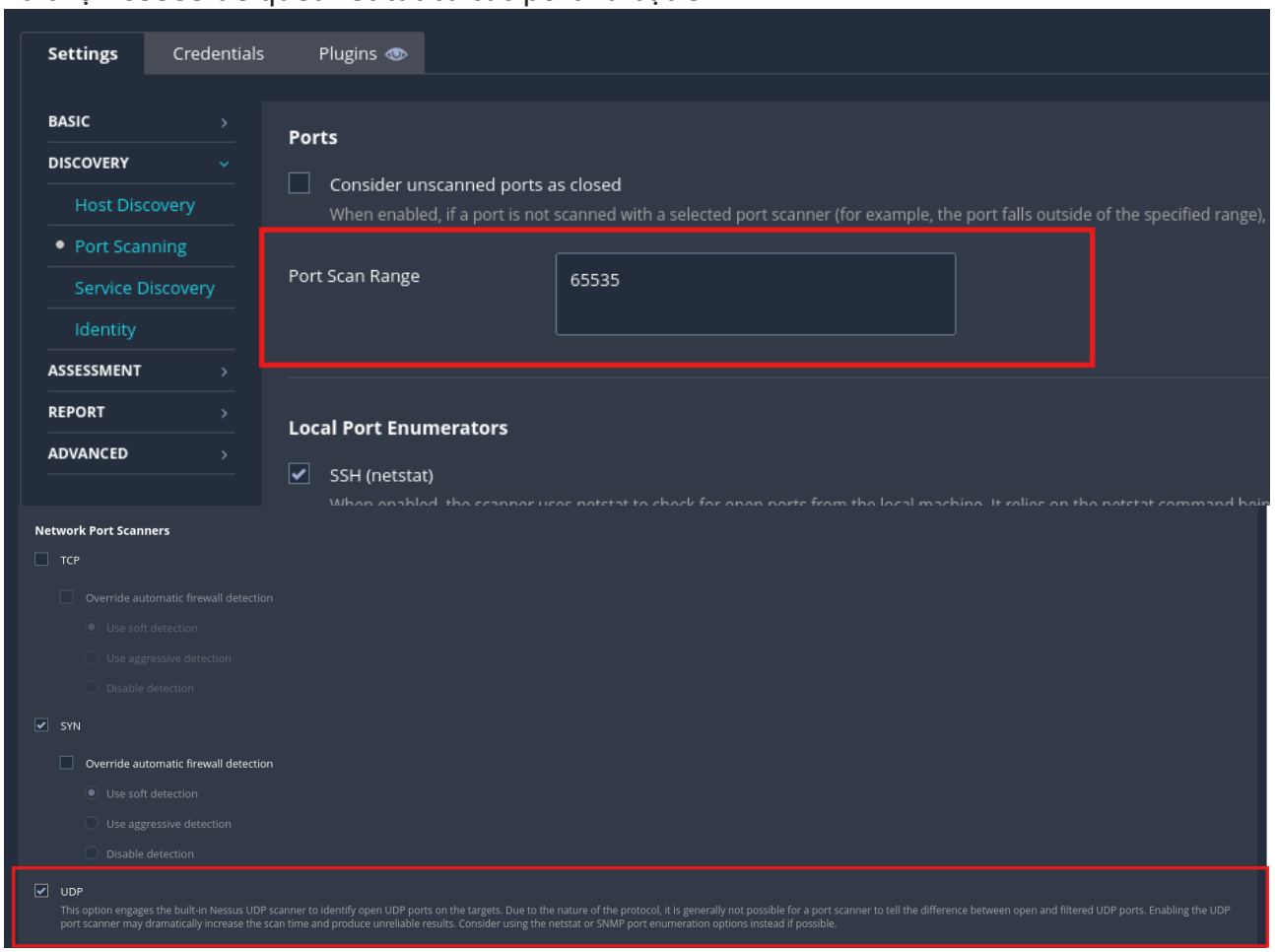
Ta tiến hành tạo 1 scan mới với cấu hình sau:



Ta chọn custom:

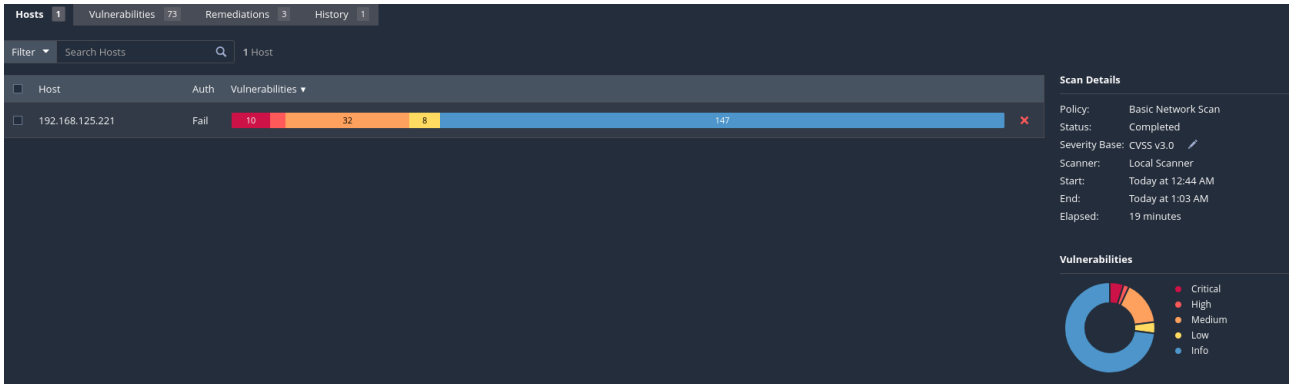


Ta chọn 65535 để quét hết tất cả các port và bật UDP:

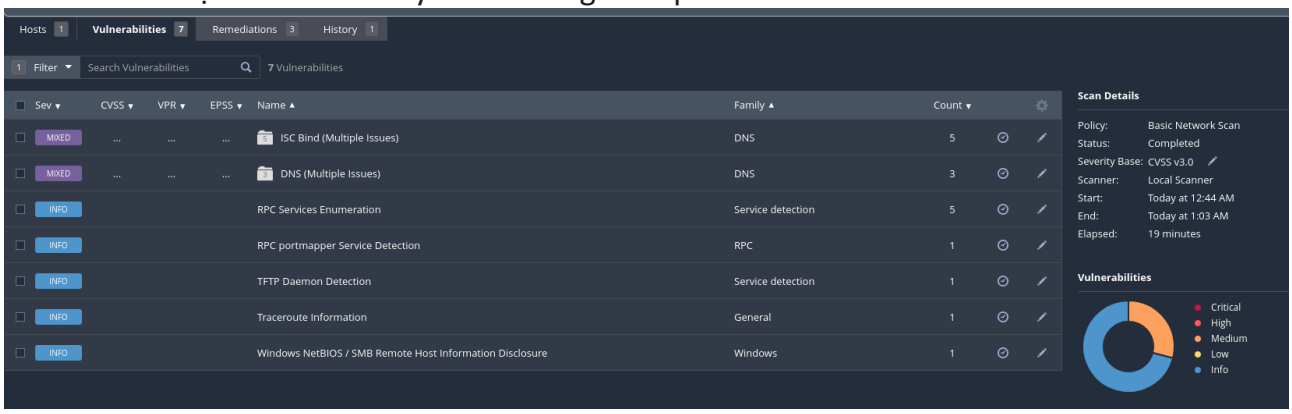


Ta tiến hành quét:

Sau khi quét xong, ta có kết quả sau:



Ta tiến hành lọc ra và tìm thấy các lỗ hổng liên quan đến UDP:

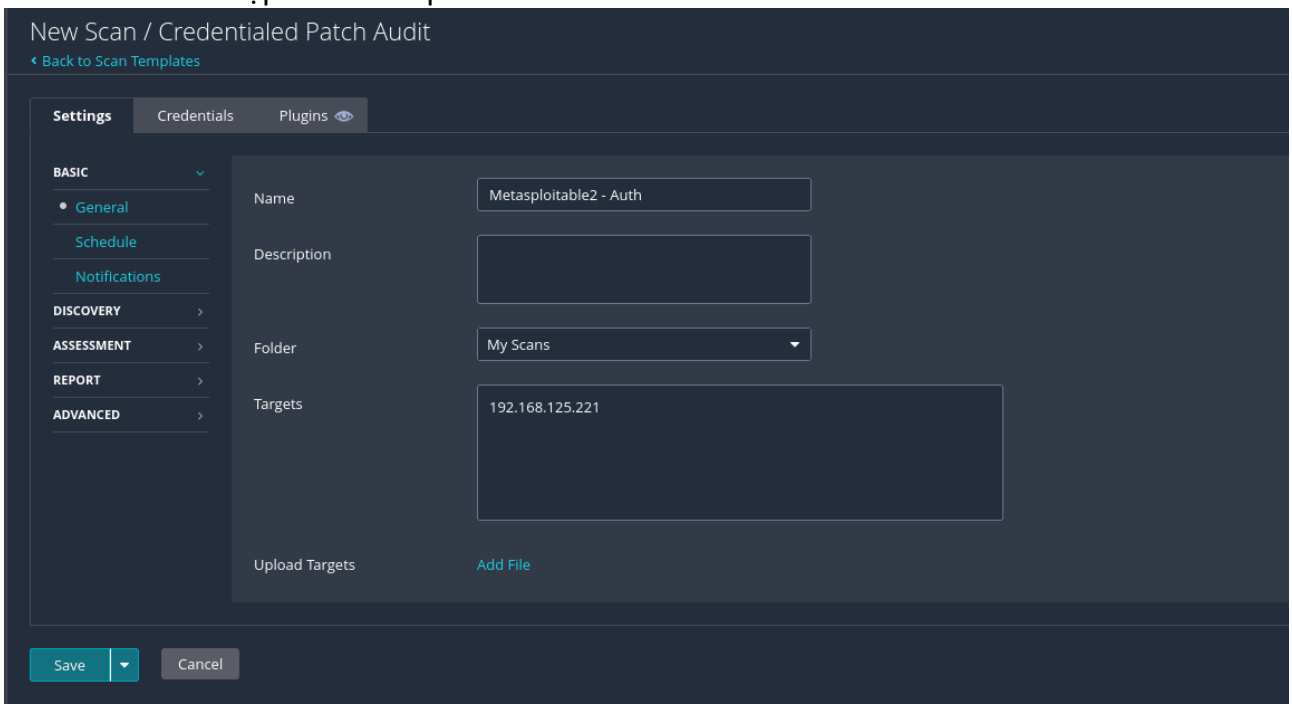


Nhiệm vụ 2.2

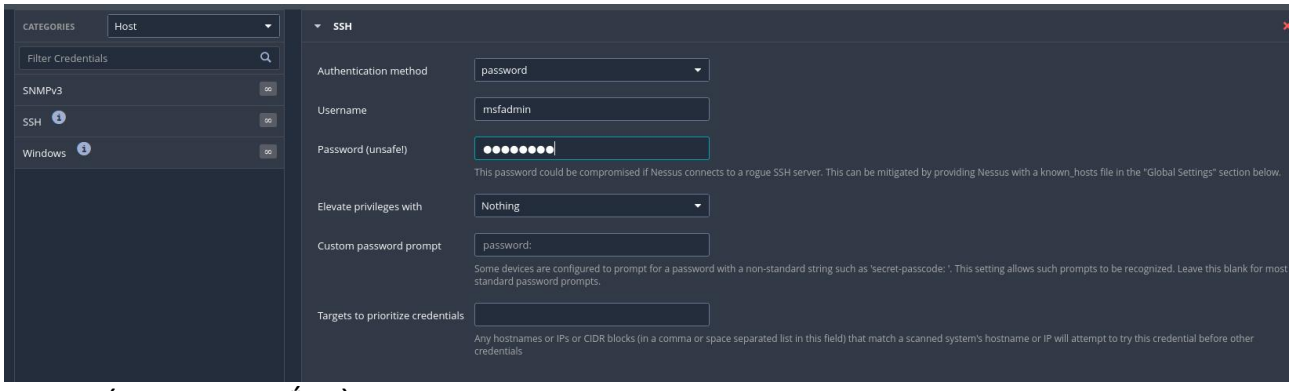
1. Thực hiện lại các bước trên để quét máy Metasploitable 2 có sử dụng tài khoản chứng thực.

Ta bắt đầu quét có sử dụng tài khoản chứng thực:

Đầu tiên là thiết lập cấu hình quét:



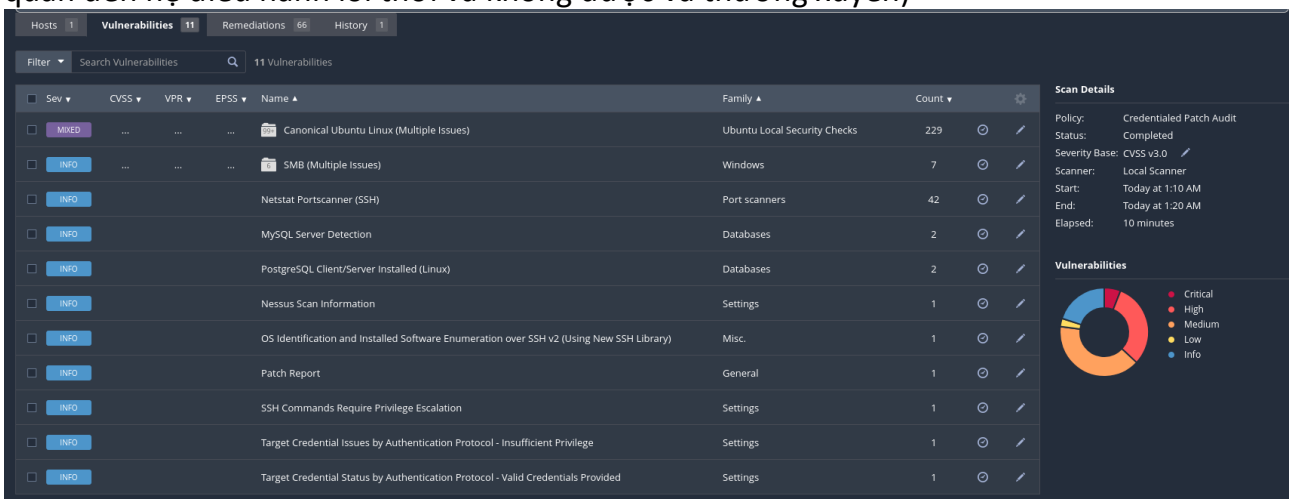
Tiếp theo, ta cấu hình SSH vào máy:



Hoàn tất lưu lại và bắt đầu quét.

Sau quét xong ta được kết quả như sau:

Chi tiết các lỗ hổng được phát hiện khi sử dụng quét chứng thực (hầu hết các lỗi chỉ đều liên quan đến hệ điều hành lỗi thời và không được vá thường xuyên)



2. Kiểm tra kết quả quét và so sánh với việc quét không sử dụng tài khoản chứng thực.

Về thời gian quét thì có chức thực hoàn thành quét nhanh gấp 2 lần và phát hiện nhiều lỗ hổng hơn nghiêm trọng hơn và nhiều hơn so với không chứng thực.

3. Hãy liệt kê các ưu, nhược điểm khi quét có tài khoản chứng thực và không có tài khoản chứng thực.

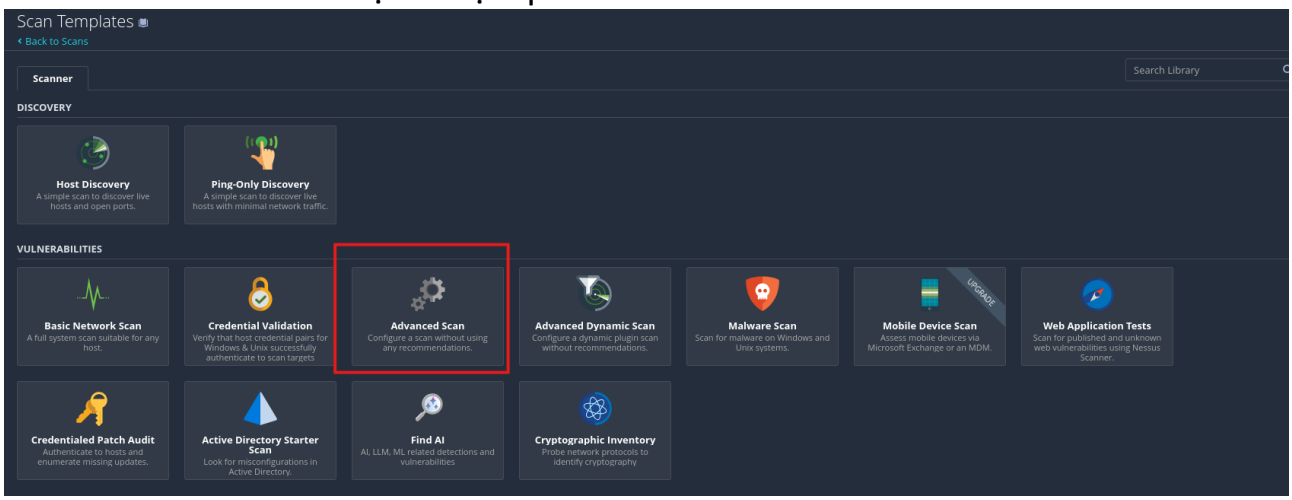
Đặc điểm	Quét có tài khoản chứng thực (Credentialed Scan)	Quét không có tài khoản chứng thực (Uncredentialed Scan)
Mô tả	Scanner được cung cấp tài khoản (ví dụ: SSH, SMB) để đăng nhập trực tiếp vào hệ thống mục tiêu như một người dùng hợp lệ.	Scanner chỉ tương tác với hệ thống từ bên ngoài mạng, giống như góc nhìn của một hacker chưa có quyền truy cập.
Ưu điểm	- **Kết quả chính xác cao, chi tiết:** Do truy cập được sâu vào hệ thống (registry, file system, package manager), scanner phát hiện được cấu hình sai, bản vá lỗi (patch) còn thiếu, ứng dụng lỗi thời mà từ bên ngoài không thấy được. - **Giảm thiểu Dương tính giả (False Positives):** Việc xác thực trực tiếp trên hệ thống giúp giảm thiểu đáng kể số lượng báo cáo lỗ hổng sai.	- **Góc nhìn thực tế của Attacker:** Cung cấp cái nhìn chính xác về những gì một kẻ tấn công thực sự có thể nhìn thấy và khai thác từ bên ngoài mạng (như các port mở, dịch vụ hiển thị công khai). - **Triển khai nhanh chóng:** Không tốn thời gian xin cấp quyền, tạo tài khoản và cấu hình thông tin đăng nhập trên scanner.

	- **Phát hiện leo thang đặc quyền:** Có khả năng tìm ra các điểm yếu có thể bị lợi dụng để nâng quyền từ user thường lên admin/root.	- **An toàn cho hệ thống mục tiêu:** Rất ít khả năng gây gián đoạn hệ thống do không thực hiện các bài kiểm tra sâu bên trong.
Nhược điểm	- **Rủi ro ảnh hưởng hệ thống:** Do chạy các bài kiểm tra sâu bên trong (ví dụ: kiểm tra tệp tin, dịch vụ), quá trình quét có thể (dù ít) làm gián đoạn hoặc gây lỗi cho hệ thống nếu không cẩn thận. Yêu cầu sự cho phép rõ ràng từ quản trị viên. - **Tốn thời gian cấu hình:** Cần phải tạo tài khoản, phân quyền phù hợp và quản lý bảo mật thông tin đăng nhập đó trên hệ thống quét.	- **Dương tính giả cao (False Positives):** Scanner chỉ dựa vào phản hồi từ bên ngoài (như banner grabbing) để đoán phiên bản phần mềm, dễ bị đánh lừa bởi firewall hoặc việc ẩn phiên bản, dẫn đến báo cáo lỗ hổng không chính xác. - **Bỏ sót lỗ hổng (False Negatives):** Không thể thấy các lỗ hổng ẩn giấu bên trong hệ thống (như lỗi cấu hình local, phần mềm cài đặt nội bộ nhưng không mở port).
Trường hợp áp dụng tốt nhất	Khi cần kiểm tra tổng thể (Audit) định kỳ, đánh giá mức độ tuân thủ (Compliance), hoặc kiểm tra tính đầy đủ của các bản vá lỗi (Patch Management) từ góc độ quản trị nội bộ.	Khi thực hiện Penetration Testing ban đầu, kiểm tra bề mặt tấn công bên ngoài (External Attack Surface), hoặc khi không có quyền/không được phép truy cập vào hệ thống.

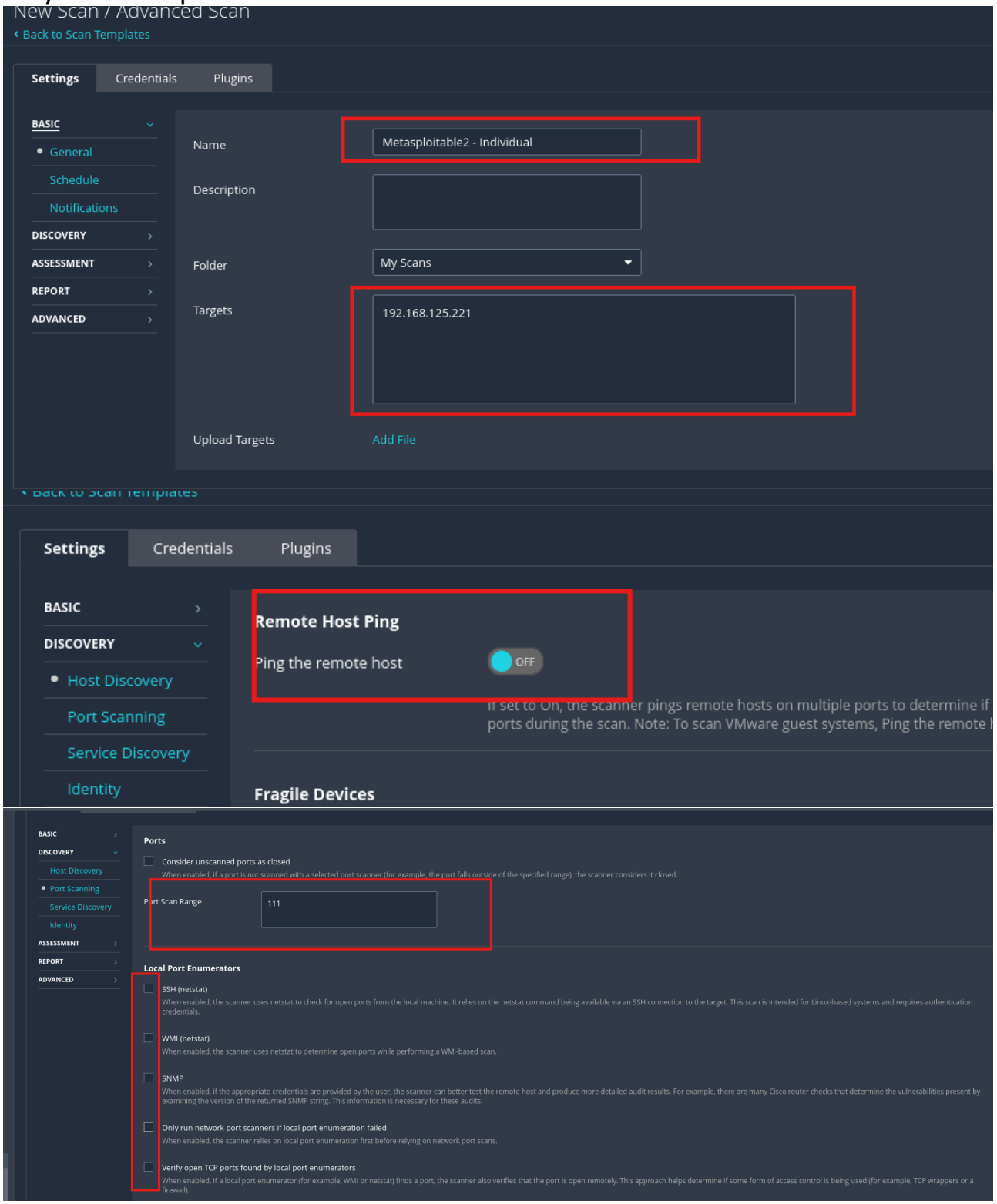
Nhiệm vụ 2.3

1. Thực hiện lại các bước trên để quét máy Metasploitable 2 sử dụng plugin NFS Exported Share Information Disclosure.

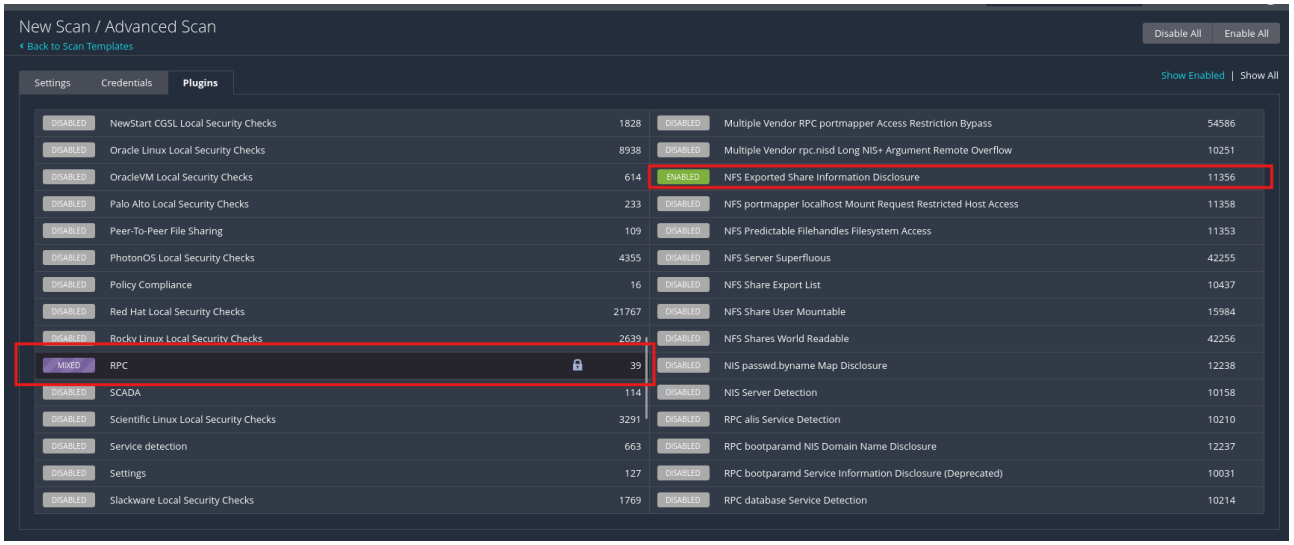
Đầu tiên ta tiến hành tạo 1 đợt quét mới:



Đặt với tên mới là Metasploitable2 – Individual và Mục tiêu quét là chọn IP của máy ảo Metasploitable2:

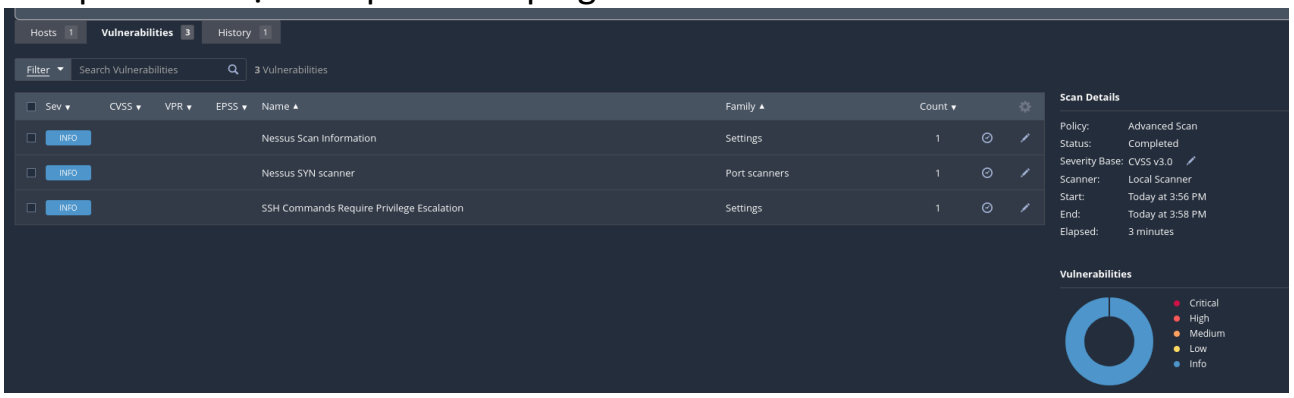


Sau đó ta cần qua phần Plugins và chọn 1 plugin duy nhất trong quá trình quét:



Tiến hành lưu lại bản quét này và chạy:

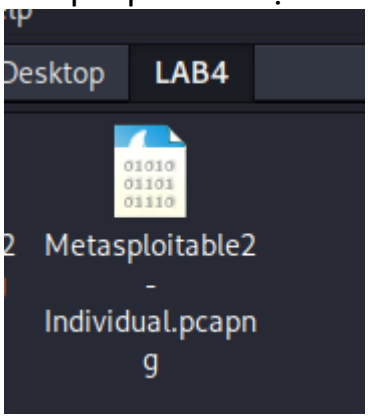
Kết quả thu được khi quét với 1 plugin như sau:



Ta có thể thấy không có lỗ hổng gì được phát hiện trong quá trình quét.

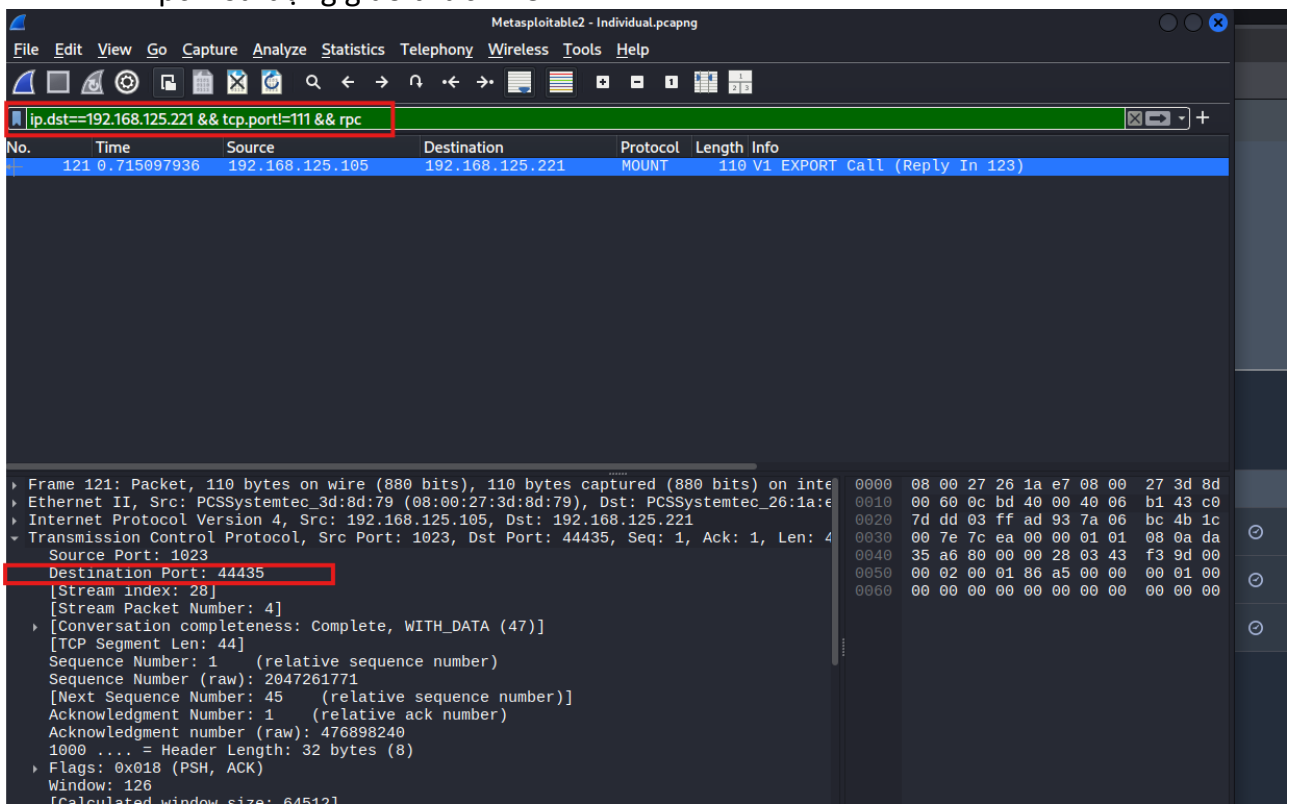
2. Chạy Wireshark hoặc tcpdump trong suốt quá trình scan sử dụng 1 plugin duy nhất. Liệt kê các port khác mà Nessus thực hiện scan, mà không phải port 111? Tại sao Nessus lại scan các port khác, trong khi chúng ta đã chỉ định chỉ scan duy nhất 1 port là 111?

File pcap thu được sau quá trình quét:



Để kiểm tra xem trong quá trình quét chỉ sử dụng một plugin duy nhất có sử dụng cổng nào khác ngoài cổng 111 hay không, trong wireshark, thực hiện lọc các gói tin trong quá trình quét với các điều kiện:

- ip.dst==192.168.125.221 – địa chỉ của máy metoploitable 2
- tcp.port!=111 – lọc ra các cổng khác cổng 111
- rpc – sử dụng giao thức RPC



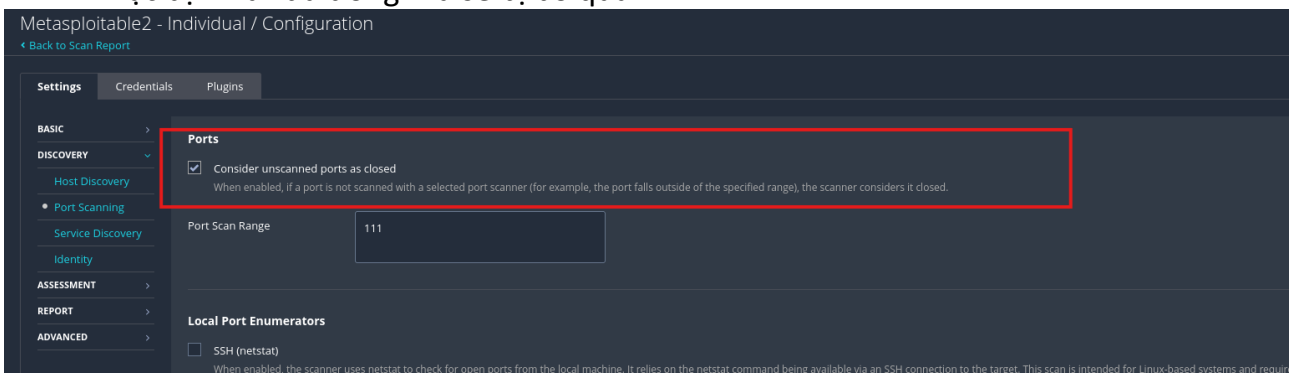
Từ kết quả thu được có thể thấy là ngoài cổng 111 ra thì Nessus còn quét thêm cổng 45777. Nguyên nhân việc Nessus quét thêm các cổng khác ngoài cổng đã được chỉ định do cơ chế hoạt động của plugin NFS Exported Share Information Disclosure. Cụ thể là dịch vụ NFS sử dụng Portmapper trên cổng 111. Thực chất cổng 111 là một cổng trung gian để truy vấn xem các cổng khác có đang thực hiện chạy dịch vụ đang được tìm kiếm hay không, sau đó thực hiện trả về kết quả, mà dịch vụ NFS không chạy trên một cổng cố định mà chạy trên một cổng ngẫu nhiên nên mặc dù đã chỉ định cổng là 111 thì vẫn xuất hiện một cổng khác trong quá trình thực hiện để có thể lấy thông tin về.

3. Mô tả cách làm để ngăn chặn việc Nessus scan port khác không phải là port được chỉ định?

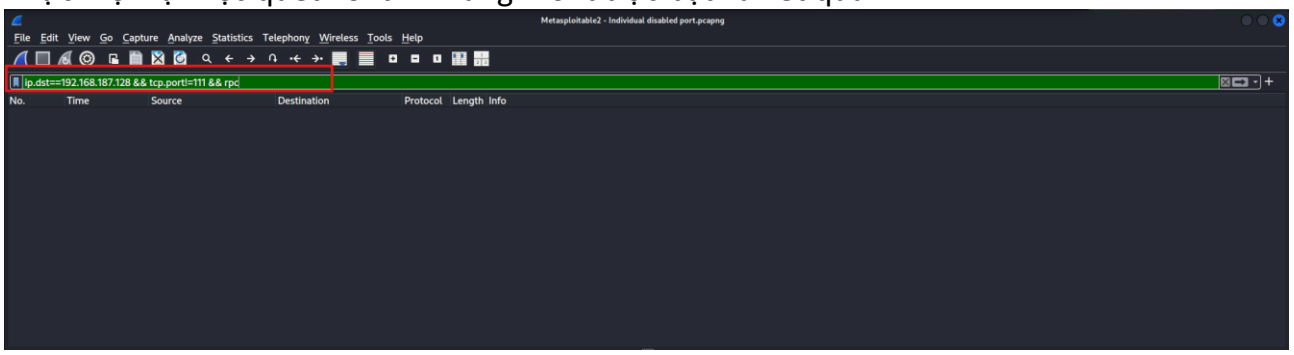
Để giới hạn Nessus chỉ quét các cổng (port) được chỉ định và ngăn chặn việc quét các cổng ngoài phạm vi, bạn có thể triển khai theo hai phương án sau:

- **Cấu hình trên máy mục tiêu (Target):** Sử dụng các giải pháp tường lửa như **Firewall**, **IPtables**... để lọc và giới hạn các kết nối đến, từ đó kiểm soát những cổng mà Nessus có thể phát hiện.
- **Cấu hình trên Nessus (Scanner):** Trong phần thiết lập **Port Scanning**, tại mục **Ports**, hãy kích hoạt tùy chọn **"Consider unscanned ports as closed"**. Khi đó, Nessus sẽ chỉ

quét các cổng nằm trong dải **Port scan range** đã khai báo; mọi cổng khác đều được mặc định là "đã đóng" và sẽ bị bỏ qua.



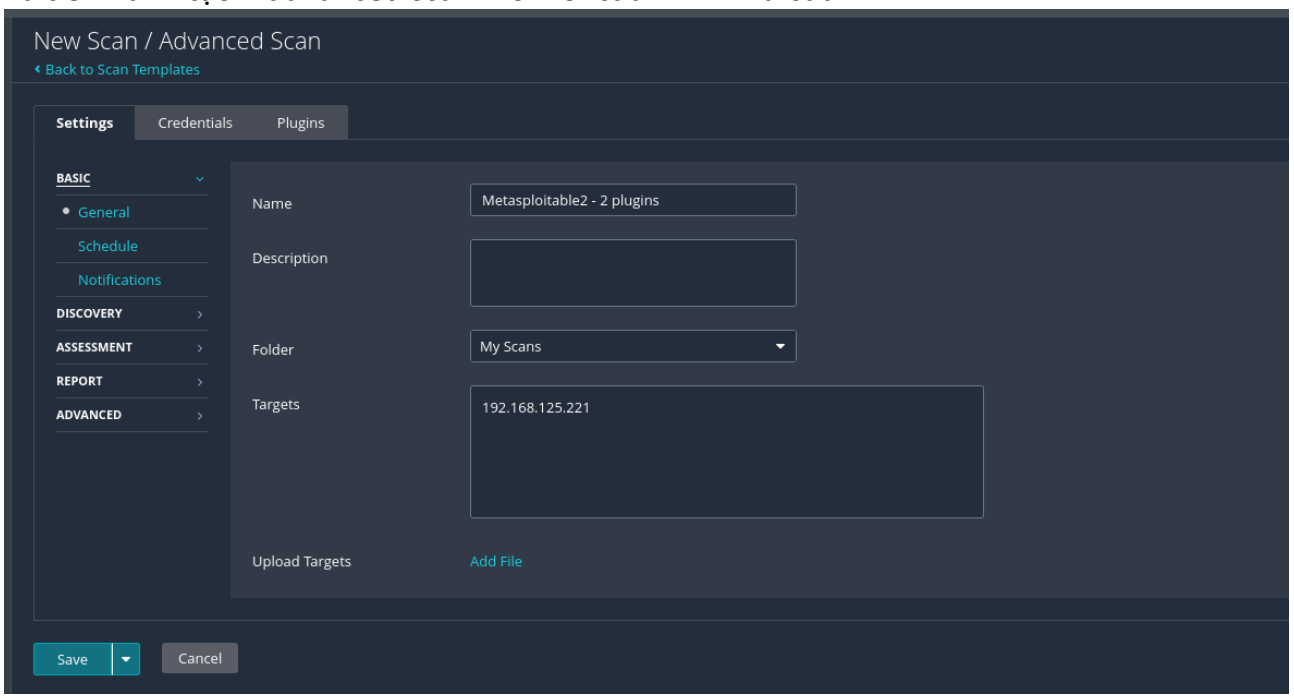
Thực hiện lại việc quét với tính năng mới được bật và kết quả:



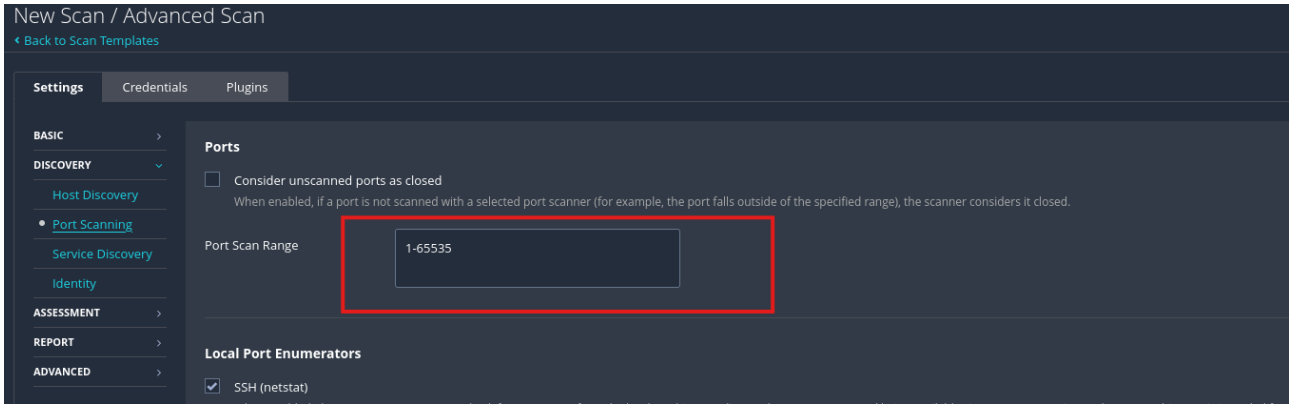
Khi ta bật tính năng “Consider unscanned ports as closed thì các port khác không còn hiện lên khi quét.

4. Thực hiện quét lại sử dụng 2 plugin khác.

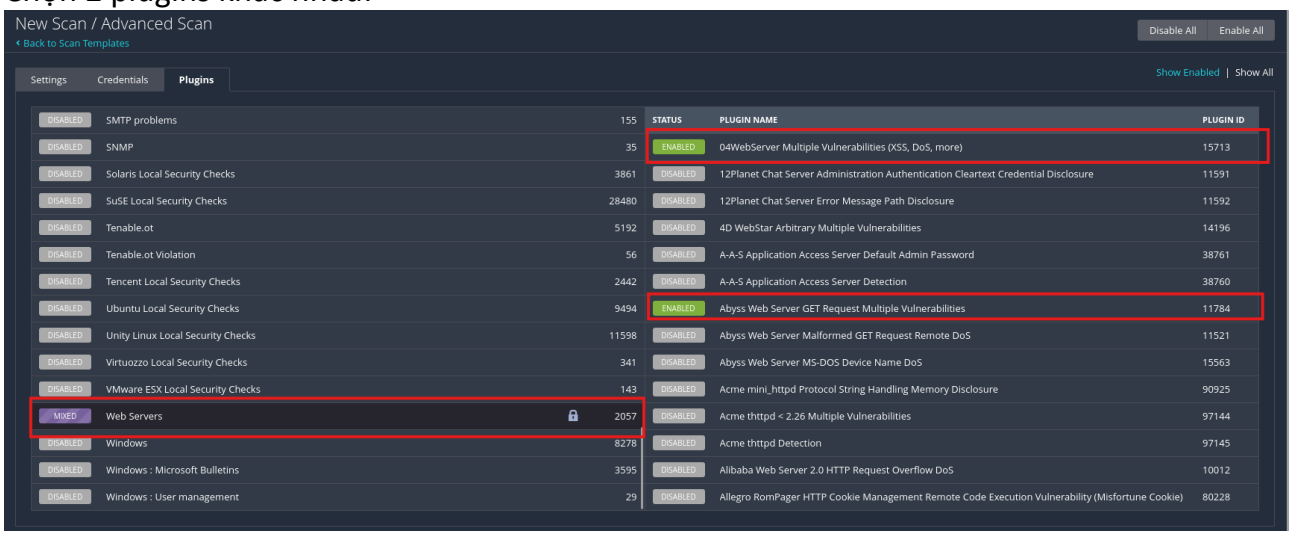
Ta tiến hành tạo 1 advanced scan mới với cấu hình như sau:



Ta tiến hành quét hết tất cả các cổng vì không biết plugins sẽ dùng cổng nào:



Chọn 2 plugins khác nhau:



Nhiệm vụ 2.4

Nhóm quyết định lựa chọn **Trivy (của Aqua Security)** làm công cụ rà quét tự động cho Nhiệm vụ 2.4 dựa trên các ưu điểm vượt trội về mặt kiến trúc, hiệu năng và tính linh hoạt trong quá trình triển khai thực tế. Cụ thể như sau:

- **Triển khai tối giản:** Chỉ cần một câu lệnh để cài đặt nhanh chóng (hoạt động rất mượt trên các máy chủ Linux như Ubuntu), không yêu cầu thiết lập cơ sở dữ liệu hay môi trường phức tạp.
- **Tốc độ quét cực nhanh:** Lưu trữ sẵn cơ sở dữ liệu lỗ hổng (cache) ngay trên máy nên thời gian quét gần như tức thời, không bị ảnh hưởng bởi độ trễ mạng.
- **Phạm vi rà soát toàn diện:** Quét hiệu quả từ các tệp tin hệ thống (filesystem), mã nguồn, cho đến các môi trường ảo hóa mạnh mẽ như Docker hay cấu hình Kubernetes; đồng thời phát hiện được cả các mật khẩu/khóa (secrets) bị rò rỉ.
- **Trích xuất báo cáo tiện lợi:** Hiển thị kết quả dạng bảng rõ ràng ngay trên màn hình dòng lệnh (CLI) và hỗ trợ xuất file HTML/JSON, rất thuận tiện để lấy hình ảnh minh chứng cho báo cáo.

Đầu tiên giờ ta tiến hành cài đặt Trivy:

```
# 1. Cài đặt các gói phụ thuộc cần thiết
sudo apt-get install wget apt-transport-https gnupg lsb-release -y
```

```
vinhnp@kali: ~
Session  Actions  Edit  View  Help
wget is already the newest version (1.25.0-2).
gnupg is already the newest version (2.4.9-4).
gnupg set to manually installed.
lsb-release is already the newest version (12.1-2).
lsb-release set to manually installed.
Solving dependencies ... Done
The following packages were automatically installed and are no longer require
d:
  libicu76 libio-pty-perl libipc-run-perl libsimdutf31 libteamdctl0
  libunibreak6 openjdk-21-jre openjdk-21-jre-headless postgresql-common-dev
  python3-pysnmp4
Use 'sudo apt autoremove' to remove them.
The following NEW packages will be installed:
  apt-transport-https
0 upgraded, 1 newly installed, 0 to remove and 53 not upgraded.
Need to get 26.5 kB of archives.
After this operation, 37.9 kB of additional disk space will be used.
Get:1 http://http.kali.org/kali kali-rolling/main amd64 apt-transport-https a
ll 3.2.0+kali1 [26.5 kB]
Fetched 26.5 kB in 1s (28.6 kB/s)
Selecting previously unselected package apt-transport-https.
(Reading database… 432561 files and directories currently installed.)
Preparing to unpack …/apt-transport-https_3.2.0+kali1_all.deb…
Unpacking apt-transport-https (3.2.0+kali1)…
Setting up apt-transport-https (3.2.0+kali1)…

┌──(vinhnp㉿kali)-[~]
└─$
```

2. Tải khóa bảo mật và lưu theo chuẩn mới (vào thư mục keyrings)
wget -qO - https://aquasecurity.github.io/trivy-repo/deb/public.key | gpg --dearmor | sudo tee /usr/share/keyrings/trivy.gpg > /dev/null

```
┌──(vinhnp㉿kali)-[~]
└─$ wget -qO - https://aquasecurity.github.io/trivy-repo/deb/public.key | gpg --dearmor | sudo tee /usr/share/keyrings/trivy.gpg > /dev/null
```

3. Thêm kho lưu trữ của Trivy (có liên kết đến khóa vừa tải)
echo "deb [signed-by=/usr/share/keyrings/trivy.gpg] https://aquasecurity.github.io/trivy-repo/deb $(lsb_release -sc) main" | sudo tee /etc/apt/sources.list.d/trivy.list

```
┌──(vinhnp㉿kali)-[~]
└─$ echo "deb [signed-by=/usr/share/keyrings/trivy.gpg] https://aquasecurity.github.io/trivy-repo/deb $(lsb_release -sc) main" | sudo tee /etc/apt/sources.list
.d/trivy.list
deb [signed-by=/usr/share/keyrings/trivy.gpg] https://aquasecurity.github.io/trivy-repo/deb kali-rolling main
```

Cập nhật lại hệ thống và tiến hành cài đặt:

sudo apt-get update
sudo apt-get install trivy -y

```
┌──(vinhnp㉿kali)-[~]
└─$ sudo apt-get update
Ign:1 https://aquasecurity.github.io/trivy-repo/deb kali-rolling InRelease
Err:2 https://aquasecurity.github.io/trivy-repo/deb kali-rolling Release
  404  Not Found [IP: 185.199.109.153 443]
Hit:3 http://http.kali.org/kali kali-rolling InRelease
Reading package lists ... Done
E: The repository 'https://aquasecurity.github.io/trivy-repo/deb kali-rolling Release' does not have a Release file.
N: Updating from such a repository can't be done securely, and is therefore disabled by default.
N: See apt-secure(8) manpage for repository creation and user configuration details.
```

Cài đặt trivy:

```
┌──(vinhnp㉿kali)-[~]
└─$ sudo apt-get install trivy -y
Reading package lists ... Done
Building dependency tree ... Done
Reading state information ... Done
Solving dependencies ... Done
The following packages were automatically installed and are no longer required:
  libicu76 libio-pty-perl libipc-run-perl libsimdutf31 libteamdctl0 libunibreak6 openjdk-21-jre openjdk-21-jre-headless postgresql-common-dev python3-pysnmp4
Use 'sudo apt autoremove' to remove them.
The following NEW packages will be installed:
  trivy
0 upgraded, 1 newly installed, 0 to remove and 53 not upgraded.
Need to get 47.1 MB of archives.
After this operation, 241 MB of additional disk space will be used.
Get:1 http://kali.download/kali kali-rolling/main amd64 trivy amd64 0.66.0-0kali1 [47.1 MB]
Fetched 47.1 MB in 2s (24.5 MB/s)
Selecting previously unselected package trivy.
(Reading database… 432565 files and directories currently installed.)
Preparing to unpack …/trivy_0.66.0-0kali1_amd64.deb…
Unpacking trivy (0.66.0-0kali1)…
Setting up trivy (0.66.0-0kali1)…
Processing triggers for kali-menu (2026.2.2)…
```

Kiểm tra phiên bản Trivy sau khi đã cài đặt:

```
┌──(vinhnp㉿kali)-[~]
└─$ trivy --version
Version: dev
```

Tiến hành quét và phân tích:

Ta sẽ dùng Trivy để quét một mục tiêu giả định. Trivy sẽ tự kéo (pull) thông tin từ Docker Hub về để quét.

Tiến hành quét thử image của một phiên bản phần mềm cũ (ví dụ: Nginx bản 1.16.0) bằng lệnh sau:

```
trivy image nginx:1.16.0
```

Sau khi Trivy tiến hành quét xong ta có thể thấy những thông tin như sau:

- **Library:** Tên thư viện bị lỗi.
- **Vulnerability ID:** Mã lỗ hổng (CVE-...).
- **Severity:** Mức độ (CRITICAL, HIGH, MEDIUM...).
- **Installed Version & Fixed Version:** Bản đang dùng và bản đã vá lỗi.
- **Title:** Tên lỗ hổng.

```
┌──(vinhnp㉿kali)-[~]
└─$ trivy image nginx:1.16.0
2026-05-02T17:02:30+08:00	INFO	[vulndb] Need to update DB
2026-05-02T17:02:30+08:00	INFO	[vulndb] Downloading vulnerability DB ...
2026-05-02T17:02:30+08:00	INFO	[vulndb] Downloading artifact ...	repo="mirror.gcr.io/aquasec/trivy-db:2"
91.98 MiB / 91.98 MiB [──────────────
```

Ta có thể thấy Trivy phát hiển 208 lỗ hổng trong image này và sau đây là phân tích chi tiết:

liblz4-1	CVE-2021-3520	CRITICAL		0.0~r131-2+b1	0.0~r131-2+deb9u1	lz4: memory corruption due to an inte ger overflow bug caused by memmove ... https://avd.aquasec.com/nvd/cve-2021-3520
	CVE-2019-17543	LOW	will_not_fix			lz4: heap-based buffer overflow in LZ4_write32 https://avd.aquasec.com/nvd/cve-2019-17543
liblzma5	CVE-2022-1271	HIGH	fixed	5.2.2-1.2+b1	5.2.2-1.2+deb9u1	gzip: arbitrary-file-write vulnerabil ity https://avd.aquasec.com/nvd/cve-2022-1271
libmount1	CVE-2016-2779		affected	2.29.2-1+deb9u1		util-linux: runuser tty hijack via TI OCSTI ioctl https://avd.aquasec.com/nvd/cve-2016-2779
	CVE-2021-37600	LOW				util-linux: integer overflow can lead to buffer overflow in get_sem_elements() in sys-utils/ipcut ils.c ... https://avd.aquasec.com/nvd/cve-2021-37600
libncurses5	CVE-2022-29458	HIGH		6.0+20161126-1+deb9u2		ncurses: segfaulting OOB read https://avd.aquasec.com/nvd/cve-2022-29458
	CVE-2018-19211	LOW	fix_deferred			ncurses: Null pointer dereference at function _nc_parse_entry in parse_entry.c https://avd.aquasec.com/nvd/cve-2018-19211
	CVE-2019-17594		affected			ncurses: heap-based buffer overflow i n the _nc_find_entry function in tinfo/comp_hash.c
libbsd0	CVE-2019-20367	CRITICAL	fixed	0.8.3-1	0.8.3-1+deb9u1	nlist.c in libbsd before 0.10.0 has a n out-of-bounds read during a com ... https://avd.aquasec.com/nvd/cve-2019-20367
libbz2-1.0	CVE-2019-12900		affected	1.0.6-8.1		bzip2: bzip2: Data integrity error wh en decompressing (with data integrity tests fail).... https://avd.aquasec.com/nvd/cve-2019-12900
libcomerr2	CVE-2022-1304	HIGH		1.43.4-2		e2fsprogs: out-of-bounds read/write v ia crafted filesystem https://avd.aquasec.com/nvd/cve-2022-1304
	CVE-2019-5094	MEDIUM	fixed		1.43.4-2+deb9u1	e2fsprogs: Crafted ext4 partition lea ds to out-of-bounds write https://avd.aquasec.com/nvd/cve-2019-5094
	CVE-2019-5188				1.43.4-2+deb9u2	e2fsprogs: Out-of-bounds write in e2f sck/rehash.c https://avd.aquasec.com/nvd/cve-2019-5188
libdb5.3	CVE-2019-8457	CRITICAL	will_not_fix	5.3.28-12+deb9u1		sqlite: heap out-of-bound read in fun ction rtreenode() https://avd.aquasec.com/nvd/cve-2019-8457
libexpat1	CVE-2022-22822		fixed	2.2.0-2+deb9u2	2.2.0-2+deb9u4	expat: Integer overflow in addBinding in xmlparse.c https://avd.aquasec.com/nvd/cve-2022-22822
	CVE-2022-22823					expat: Integer overflow in build_mode l in xmlparse.c

libxslt1.1 rite routines security 11068	CVE-2019-11068	CRITICAL		1.1.29-2.1	1.1.29-2.1+deb9u1	libxslt: xsltCheckRead and xsltCheckW bypass by crafted URL https://avd.aquasec.com/nvd/cve-2019-
xt in transform.c could 18197	CVE-2019-18197	HIGH			1.1.29-2.1+deb9u2	libxslt: use after free in xsltCopyTe lead to information ... https://avd.aquasec.com/nvd/cve-2019-
ormat strings could 13117	CVE-2019-13117	LOW			1.1.29-2.1+deb9u1	libxslt: an xsl number with certain f lead to a ... https://avd.aquasec.com/nvd/cve-2019-
data due to too narrow 13118	CVE-2019-13118					libxslt: read of uninitialized stack xsl:number instruction ... https://avd.aquasec.com/nvd/cve-2019-
login users tool 12424	CVE-2017-12424	CRITICAL		1:4.4-4.1	1:4.4-4.1+deb9u1	shadow-utils: Buffer overflow via new https://avd.aquasec.com/nvd/cve-2017-
5-1 for Shadow 20002	CVE-2017-20002	HIGH				The Debian shadow package before 1:4. incorrectly lists https://avd.aquasec.com/nvd/cve-2017-
ileged user to drop	CVE-2018-7169	LOW	affected			shadow-utils: newgidmap allows unpriv supplementary groups potentially allo

Ta phân tích 1 số lỗ hổng như sau:

Lỗ hổng trong thư viện quản lý gói dpkg (Mức độ: CRITICAL)

- **Mã lỗ hổng (Vulnerability ID):** CVE-2022-1664
- **Mức độ nghiêm trọng (Severity):** CRITICAL (Nghiêm trọng nhất)
- **Thư viện/Gói bị ảnh hưởng (Library):** dpkg (Debian package management)
- **Phiên bản đang cài đặt (Installed Version):** 1.18.25
- **Phiên bản đã vá lỗi (Fixed Version):** 1.18.26
- **Mô tả lỗ hổng:** Trivy cảnh báo một lỗ hổng trong mã nguồn lưu trữ (Archive) của dpkg. Mặc dù mô tả chi tiết bị cắt ngang trong ảnh (Dpkg::Source::Archive in dpkg, the Debian system, b ...), nhưng với mức độ CRITICAL, đây thường là lỗi cho phép kẻ tấn công thực thi mã từ xa (RCE) hoặc thao túng file hệ thống khi giải nén các gói phần mềm độc hại.
- **Đề xuất khắc phục:** Cần tiến hành cập nhật gói dpkg lên phiên bản 1.18.26 hoặc mới hơn ngay lập tức thông qua trình quản lý gói của hệ điều hành.

Lỗ hổng rò rỉ và ghi đè bộ nhớ trong e2fsprogs (Mức độ: HIGH & MEDIUM)

- **Mã lỗ hổng:** CVE-2022-1304 (HIGH) và CVE-2019-5094 (MEDIUM)
- **Thư viện/Gói bị ảnh hưởng:** e2fslibs / e2fsprogs
- **Phiên bản đang cài đặt:** 1.43.4-2
- **Phiên bản đã vá lỗi:** Lỗi CVE-2019-5094 đã được vá ở bản 1.43.4-2+deb9u1.
- **Mô tả lỗ hổng:**
  - **CVE-2022-1304 (HIGH):** Lỗi đọc/ghi ngoài vùng nhớ đệm (out-of-bounds read/write) khi xử lý một file hệ thống được tạo thủ công (crafted filesystem). Kẻ tấn công có thể lợi dụng lỗi này để gây treo ứng dụng (Crash) hoặc có khả năng thực thi mã tùy ý.

  - **CVE-2019-5094 (MEDIUM):** Lỗ hổng cho phép kẻ tấn công thao túng phân vùng ext4 được thiết kế đặc biệt để gây ra lỗi rò rỉ bộ nhớ hoặc ghi đè dữ liệu.
- **Đề xuất khắc phục:** Nâng cấp gói e2fsprogs và các thư viện liên quan lên phiên bản mới nhất được hỗ trợ bởi bản phân phối (ít nhất là 1.43.4-2+deb9u1 để xử lý các lỗi cũ).

Lỗ hổng đọc dữ liệu ngoài vùng nhớ trong libbsd0 (Mức độ: CRITICAL)

- **Mã lỗ hổng:** CVE-2019-20367
- **Mức độ nghiêm trọng:** CRITICAL
- **Thư viện/Gói bị ảnh hưởng:** libbsd0
- **Phiên bản đang cài đặt:** 0.8.3-1
- **Phiên bản đã vá lỗi:** 0.8.3-1+deb9u1
- **Mô tả lỗ hổng:** Lỗi đọc dữ liệu ngoài vùng nhớ đệm (out-of-bounds read) xảy ra trong hàm nlist.c của thư viện libbsd ở các phiên bản trước 0.10.0. Lỗ hổng này có thể bị lợi dụng để đánh cắp thông tin nhạy cảm từ bộ nhớ hoặc gây gián đoạn dịch vụ (Denial of Service - DoS).
- **Đề xuất khắc phục:** Cập nhật ngay thư viện libbsd0 lên phiên bản 0.8.3-1+deb9u1 để vá lỗ hổng rò rỉ bộ nhớ này.

Sau phần phân tích này ta biết được rằng:

1. Trivy được dùng cho những mục đích gì?

Trivy là một máy quét bảo mật toàn diện (Comprehensive Security Scanner), tập trung giải quyết 4 bài toán cốt lõi sau:

- **Quét Container Image (Mục đích phổ biến nhất):** Phát hiện các lỗ hổng bảo mật (CVE) nằm trong hệ điều hành nền hoặc các thư viện được đóng gói bên trong Docker Image trước khi mang đi triển khai chạy thực tế.
- **Quét Hệ thống tập tin & Mã nguồn (Filesystem/Git Repo):** Rà soát trực tiếp các thư mục chứa mã nguồn dự án để tìm ra các gói thư viện lập trình (npm, pip, composer...) đang sử dụng phiên bản cũ và có chứa lỗ hổng.
- **Quét Lỗi cấu hình hạ tầng (Misconfiguration / IaC):** Kiểm tra các file cấu hình như Dockerfile, Kubernetes YAML, Terraform xem có vi phạm các nguyên tắc bảo mật hay không (ví dụ: cấp quyền root không cần thiết, mở sai port).
- **Dò tìm thông tin nhạy cảm (Secret Scanning):** Tự động quét và phát hiện các mật khẩu, API keys, hoặc Token bị lập trình viên vô tình "hard-code" (gõ trực tiếp) vào trong các tệp tin văn bản hoặc mã nguồn.

2. Chốt ý bản chất của Trivy (Điểm khác biệt cốt lõi)

- **Quét từ "bên trong" thay vì "bên ngoài":** Nếu Nessus hay OpenVAS là dạng *Network Scanner* (đứng từ xa, dò quét qua card mạng để xem dịch vụ nào hổng), thì Trivy là dạng *Artifact Scanner* (đi sâu vào tận cùng các file, thư viện và mã nguồn để bóc tách lỗi).
- **Công cụ của kỷ nguyên Cloud & DevOps:** Với đặc điểm siêu nhẹ (chỉ là 1 file chạy), không cần thiết lập Database rườm rà, thực thi bằng một dòng lệnh và tốc độ quét gần như tức thời, Trivy sinh ra là để tích hợp tự động vào các quy trình phát triển phần mềm hiện đại (CI/CD Pipeline).

HẾT